MF0487_3

تقرير تدقيق أمن المعلومات

المحللة: بالوما كاسابونا (Paloma Casabona)

بناءً على طلب: ميغيل إيرناندیث (Miguel Hernández)، شركة Sysdig

ترجمة كاملة إلى العربية الفصحى الحديثة عن الأصل الإسباني. حُفظت جميع الأقسام والجداول والحواشي والصور. أُبقيت الأوامر والشيفرات والعناوين وأسماء الملفات والمعرّفات التقنية وقيم FLAG دون تغيير. أُدرجت لقطات الشاشة الأصلية بوصفها أدلة، وأضيفت ترجمة نصوصها ذات المعنى بجانبها. حُفظ التكرار والتباين الموجودان في الأصل. تتيح علامات «صفحة الأصل» مطابقة الترجمة مع صفحات ملف PDF الأصلي البالغ عددها 47 صفحة.

> أجرِ تدقيقًا أمنيًا لعنوان IP المقدَّم (3.88.28.22)، وأكمل المستند بجميع الأدلة التي تعثر عليها. بعد الانتهاء، ارفعه إلى GH وأرسل الرابط.



MegaCorp web server

Página por defecto. Este servidor aloja varios **hosts virtuales por nombre** (*name-based virtual hosts*).

Has llegado a esta página **por IP**, así que estás viendo el sitio por defecto (*fallback*). Las aplicaciones reales viven en nombres de host distintos y se seleccionan mediante la cabecera HTTP `Host` — no existe DNS público para ellas.

Objetivo del examen

Realiza una **auditoría de seguridad autorizada** de *este único host*. Hay **flags** con el formato `FLAG{...}` repartidas por los servicios; cada una corresponde a una vulnerabilidad o mala configuración real. Documenta cada hallazgo en el **informe**: qué es, cómo lo encontraste (herramienta + comando), la evidencia (flag) y una mitigación.

Cómo llegar a los sitios reales

Este servidor sirve *varios* sitios detrás de esta misma IP. Elige cuál ver poniendo la cabecera `Host:` — no hace falta DNS, la fijas tú.

ترجمة النص الظاهر في لقطة الشاشة

خادم الويب الخاص بشركة MegaCorp

هذه هي الصفحة الافتراضية. يستضيف هذا الخادم عدة مضيفات افتراضية قائمة على الأسماء.

لقد وصلت إلى هذه الصفحة باستخدام عنوان IP، ولذلك ترى الموقع الافتراضي الاحتياطي. توجد التطبيقات الفعلية على أسماء مضيفات مختلفة، ويُختار التطبيق عبر ترويسة HTTP المسماة `Host`؛ ولا توجد لها سجلات DNS عامة.

هدف الامتحان

أجرِ تدقيقًا أمنيًا مصرحًا به لهذا المضيف وحده. تتوزع رموز إثبات بصيغة `FLAG{...}` على الخدمات، ويقابل كل منها ثغرة حقيقية أو إعداد غير سليم. وثّق كل نتيجة في التقرير: ماهيتها، وكيف عثرت عليها (الأداة + الأمر)، والدليل (رمز الإثبات)، وإجراء للتخفيف من الخطر.

كيفية الوصول إلى المواقع الفعلية

يقدّم هذا الخادم عدة مواقع خلف عنوان IP نفسه. اختر الموقع الذي تريد عرضه بتعيين ترويسة `Host:`؛ لا حاجة إلى DNS، فأنت تحدد القيمة بنفسك.

الحقل	القيمة
العميل / الهدف	MegaCorp - 3.88.28.22 / megacorp.lab
نوع التدقيق	خارجي، بأسلوب الصندوق الأسود
المدققون	بالوما كاسابونا أغودو (Paloma Casabona Agudo)
تاريخ البدء	2026/07/02
تاريخ الانتهاء	2026/07/02
إصدار التقرير	1.0
التصنيف	سري

1. الملخص التنفيذي

سياق التدقيق وهدفه

هدف هذا التدقيق الأمني إلى تقييم مدى انكشاف الخدمات التي تنشرها شركة MegaCorp، من خلال تحديد ثغرات الإعداد وأخطاء النشر والمخاطر المحتملة الناتجة عن إفشاء المعلومات الحساسة. ولهذا الغرض، نُفذت أعمال استطلاع وحصر وتحقق يدوي من الخدمات التي يمكن الوصول إليها عبر الشبكة.

التقييم العام للمخاطر

مرتفع. حُددت ثغرات متعددة في الإعدادات أتاحت الوصول إلى موارد داخلية، واكتشاف معلومات حساسة عن البنية التحتية، والعثور على مستودعات مكشوفة للشيفرة المصدرية؛ مما يزيد سطح الهجوم بدرجة كبيرة.

الاستنتاجات الرئيسية

- حُددت عدة مضيفات افتراضية داخلية يمكن الوصول إليها من الإنترنت بتعديل ترويسة `Host`.
- كشفت شهادة TLS عن معلومات داخلية تتعلق بالبنية التحتية، مما أتاح اكتشاف خدمات ونطاقات جديدة.
- عُثر على مستودعات Git مكشوفة، مع خطر إفشاء الشيفرة المصدرية والمعلومات الحساسة.
- اكتُشفت لوحة مراقبة داخلية متاحة دون مصادقة، وخدمات داخلية منشورة على منافذ غير قياسية.
- لوحظت أوجه قصور متعددة في الإعدادات وغياب إجراءات التقوية الأمنية في الخدمات الخاضعة للتدقيق.

التوصيات ذات الأولوية

1. إزالة مستودعات `.git` وأي معلومات حساسة مكشوفة على خوادم الإنتاج.

2. تقييد الوصول إلى الخدمات الداخلية باستخدام المصادقة وتقسيم الشبكة وقواعد الجدار الناري.

3. مراجعة إعدادات خوادم الويب وشهادات TLS، وتطبيق إجراءات التقوية الأمنية وتعطيل عرض محتويات الأدلة.

ملخص النتائج بحسب درجة الخطورة

درجة الخطورة	عدد النتائج
حرجة	0
مرتفعة	4
متوسطة	6
منخفضة	1
معلوماتية	0
الإجمالي	11

يتسق هذا التوزيع (0 حرجة و4 مرتفعة و6 متوسطة و1 منخفضة) مع النتائج التي وثقتموها: فمعظمها أخطاء إعداد ذات أثر مهم، ولكن دون دليل على تنفيذ شيفرة عن بُعد أو اختراق كامل للنظام؛ ولذلك فإن تصنيف المخاطر العامة بأنها مرتفعة له ما يبرره بوضوح.

2. النطاق وقواعد الاشتباك

• **الأصول المشمولة بالنطاق:** عنوان IP 3.88.28.22 وجميع الخدمات المرتبطة به، مثل HTTP وHTTPS وFTP وRedis وغيرها من الخدمات المكشوفة، بما فيها المضيفات الافتراضية المكتشفة: `www.megacorp.lab` و`dev.megacorp.lab` و`admin.megacorp.lab` و`api.megacorp.lab` و`internal.megacorp.lab` و`staging.megacorp.lab` و`vpn.megacorp.lab`.

• **الأصول الخارجة عن النطاق:** أي نظام أو شبكة أو خدمة لا ترتبط بعنوان IP المستهدف، أو لم يُصرَّح صراحةً بتدقيقها.

• **الفترة الزمنية المصرح بها:** أثناء تنفيذ التدريب العملي / الامتحان، وضمن الوقت المحدد لإنجازه.

• **عناوين IP المصدرية للمدقق:** جهاز المدقق العامل بنظام Kali Linux، بعنوان IP مُسنَد داخل بيئة التدريب.

• **القيود (RoE):**

• عدم تنفيذ هجمات حجب الخدمة (DoS/DDoS).

• عدم تنفيذ هجمات تخمين شامل ضد خدمات المصادقة.

• عدم تعديل معلومات النظام المستهدف أو حذفها أو تغييرها.

• عدم الانتقال إلى أنظمة أو شبكات أخرى خارج النطاق المحدد.

• حصر الاختبارات في تقنيات الاستطلاع والحصر والتحقق من الثغرات المصرح بها.

القيود التي ظهرت أثناء العمل

لم يكن من الممكن أثناء التدقيق تقييم الخدمات غير المكشوفة للعامة، أو الخدمات التي تتطلب بيانات اعتماد صالحة. اقتصرت الاختبارات على المعلومات والخدمات المتاحة من بيئة التدريب المصرح بها، مع الالتزام الدائم بقواعد الاشتباك المحددة.

3. المنهجية

أُجري التدقيق وفق منهجية مستلهمة من معيار تنفيذ اختبار الاختراق PTES ومن دليل OWASP لاختبار أمن تطبيقات الويب WSTG، مع تقسيم العمل إلى مراحل لتحديد ثغرات الإعداد وانكشاف المعلومات.

1. الاستطلاع واكتشاف الخدمات

حُددت في هذه المرحلة الخدمات التي يكشفها الهدف باستخدام فحص المنافذ واكتشاف الإصدارات. كما حُللت شهادات TLS للحصول على معلومات عن البنية التحتية والمضيفات الافتراضية المحتملة.

الأدوات المستخدمة: Nmap وOpenSSL.

2. حصر موارد الويب

حُصرت المضيفات الافتراضية بتعديل ترويسة HTTP المسماة `Host`، كما حُددت الأدلة وموارد الويب ومستودعات Git المكشوفة. واستُخدمت أدوات لإرسال طلبات HTTP والتحقق من وجود الموارد التي يمكن الوصول إليها.

الأدوات المستخدمة: cURL وGobuster وWget.

3. تحليل الثغرات

جرى التحقق يدويًا من الإعدادات غير الآمنة المكتشفة أثناء الحصر، من خلال فحص انكشاف الخدمات الداخلية ومستودعات Git ولوحات المراقبة وقوائم محتويات الأدلة وشهادات TLS التي تتضمن معلومات حساسة.

الأدوات المستخدمة

الأداة	الإصدار	استخدامها في هذا التدقيق
Nmap	7.95	اكتشاف المنافذ والخدمات والإصدارات.
OpenSSL	3.x	فحص شهادة TLS واستخراج الأسماء البديلة SAN.
cURL	8.x	حصر المضيفات الافتراضية والوصول إلى موارد HTTP.
Gobuster	3.8	حصر الأدلة وموارد الويب.
Wget	1.x	تنزيل الموارد ومستودع Git المكشوف.
Git	2.x	فحص مستودع Git المكشوف.

يعكس هذا القسم ما نفذته فعلًا أثناء التدقيق، وهو أكثر متانة من إدراج أدوات لم تستخدمها.

4. سطح الهجوم المكتشف

4. سطح الهجوم المكتشف

4.1. المنافذ والخدمات

المنفذ	البروتوكول	الخدمة	الإصدار / لافتة التعريف	ملاحظات
21	TCP	FTP	vsftpd 3.0.5	خدمة FTP متاحة للوصول.
80	TCP	HTTP	Apache httpd	الموقع الرئيسي لشركة MegaCorp.
443	TCP	HTTPS	Apache httpd (TLS)	شهادة موقعة ذاتيًا تتضمن معلومات داخلية في SAN.
6379	TCP	Redis	Redis Key-Value Store	خدمة Redis مكشوفة.
8000	TCP	HTTP	nginx 1.27.5	تطبيق Legacy Billing مع مستودع `.git` مكشوف.

المنفذ	البروتوكول	الخدمة	الإصدار / لافتة التعريف	ملاحظات
8080	TCP	HTTP	Caddy httpd	لوحة مراقبة متاحة دون مصادقة.

4.2. المضيفات الافتراضية والمسارات المهمة

المضيف / المسار	طريقة اكتشافه	ملاحظات
www.megacorp.lab	شهادة TLS (SAN)	موقع الشركة.
dev.megacorp.lab	شهادة TLS (SAN)	بيئة تطوير؛ تشير إلى تفعيل عرض محتويات الأدلة.
admin.megacorp.lab	شهادة TLS (SAN)	مضيف افتراضي حُدد أثناء الحصر.
api.megacorp.lab	شهادة TLS (SAN)	واجهة API عامة؛ تشير إلى `/swagger.json`.
internal.megacorp.lab	شهادة TLS + الحصر عبر Host	مضيف داخلي متاح دون مصادقة؛ يتضمن معلومات حساسة ورمز FLAG.
staging.megacorp.lab	شهادة TLS (SAN)	بيئة ما قبل الإنتاج؛ تذكر نسخة احتياطية في دليل الويب.

المضيف / المسار	طريقة اكتشافه	ملاحظات
vpn.megacorp.lab	شهادة TLS + الحصر عبر Host	بوابة VPN؛ تؤكد تسرب الأسماء الداخلية عبر شهادة TLS.
/.git/	الحصر اليدوي	مستودع Git مكشوف في تطبيق Legacy Billing على المنفذ 8000.
/swagger.json	صفحة API	فهرس نقاط نهاية واجهة API.
/status.txt	صفحة المراقبة	مورد تشير إليه لوحة المراقبة على المنفذ 8080.

يلخص هذا القسم كامل سطح الهجوم الذي حددته أثناء التدقيق، ويرتبط تمامًا بالنتائج اللاحقة.

5. النتائج التفصيلية

مقياس الخطورة المرجعي

درجة الخطورة	الوصف
حرجة	اختراق مباشر: تنفيذ شيفرة عن بُعد، أو سرقة بيانات اعتماد، أو وصول كامل إلى البيانات.
مرتفعة	وصول مهم أو انكشاف بيانات حساسة بجهد قليل.
متوسطة	تتطلب شروطًا معينة أو سلسلة من الخطوات؛ أثر متوسط.
منخفضة	أثر محدود أو صعوبة في الاستغلال.
معلوماتية	ممارسات جيدة / تحسين الرؤية، دون أثر مباشر.

[F-01] الوصول المجهول إلى خدمة FTP

الحقل / القيمة

الحقل	القيمة
المعرّف	F-01
درجة الخطورة	متوسطة
CVSS 3.1	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
الأصل المتأثر	3.88.28.22:21/tcp
الفئة	إعداد غير آمن / وصول مجهول إلى FTP
الحالة	مفتوحة

الوصف

حُددت أثناء الاستطلاع خدمة FTP (vsftpd 3.0.3) متاحة من الإنترنت مع تفعيل المصادقة المجهولة. يتيح هذا الإعداد لأي مستخدم الاتصال بالخادم دون بيانات اعتماد، ويكشف معلومات قد تسهّل هجمات لاحقة.

الأثر

يزيد الوصول المجهول إلى FTP سطح الهجوم لأنه يسمح للمستخدمين غير المصادق عليهم باستعراض الملفات المخزنة على الخادم وتنزيلها. وقد يكشف ذلك بيانات حساسة ويسهّل استغلال ثغرات أخرى.

الأدلة / إثبات المفهوم

استطلاع الخدمة

```
nmap -sC -sV 3.88.28.22
```

المقتطف المهم:

```
21/tcp open ftp vsftpd 3.0.3
```

الترجمة: المنفذ `21/tcp` مفتوح، والخدمة FTP، والإصدار vsftpd 3.0.3.

```
ftp-anon: Anonymous FTP login allowed (FTP code 230)
-r--r--r-- 1 0 0 138 Jun 25 16:10 flag.txt
-r--r--r-- 1 0 0 431 Jun 25 16:10 welcome.txt
```

الترجمة: يُسمح بتسجيل الدخول المجهول إلى FTP، برمز استجابة 230. الملفان المتاحان هما `flag.txt` بحجم 138 بايت و`welcome.txt` بحجم 431 بايت، بتاريخ 25 يونيو، الساعة 16:10، مع أذونات الوصول المبينة في المخرجات.

التحقق اليدوي

```
ftp 3.88.28.22
```

اسم المستخدم: `anonymous`

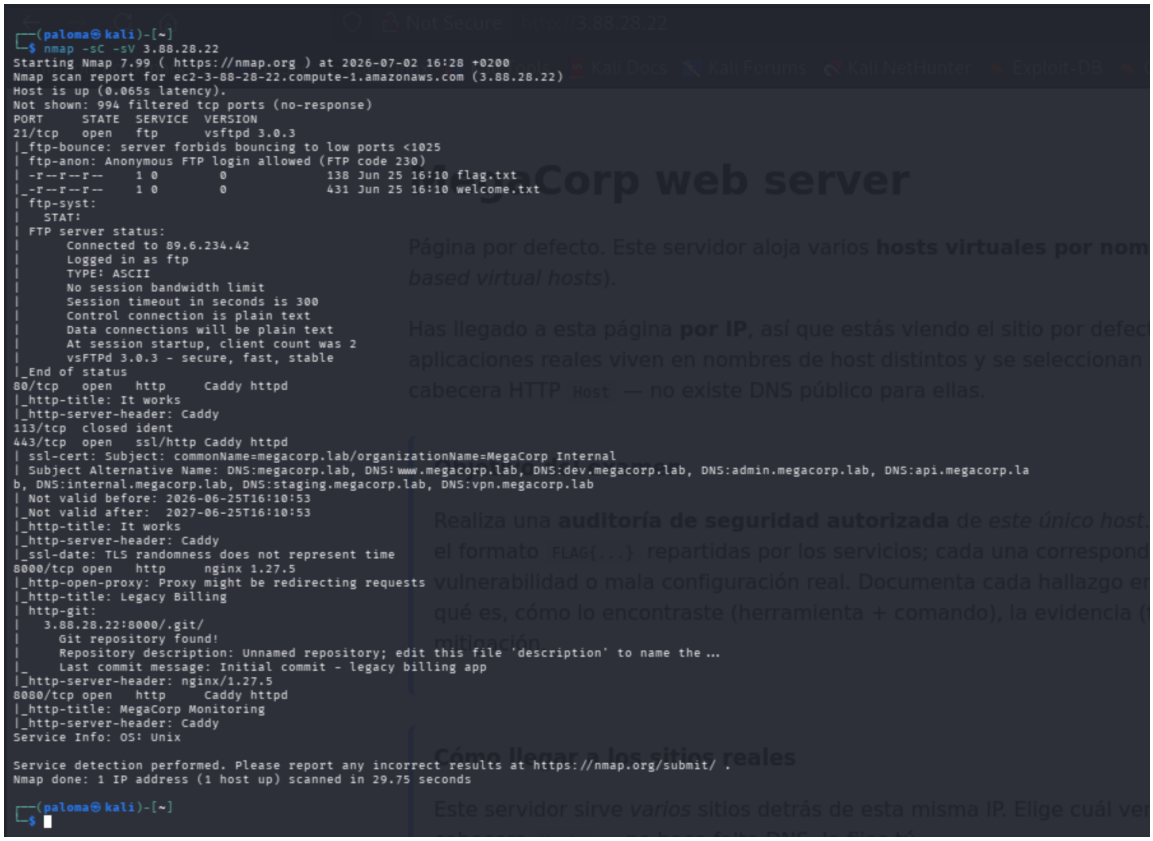
الأوامر المنفذة:

```
ls
get flag.txt
bye
cat flag.txt
```

رمز الإثبات المستخرج

```
FLAG{ftp_anonymous_access}
```

لقطة الدليل:



ترجمة الرسائل الظاهرة في لقطة الشاشة

بدأ تشغيل Nmap 7.99 في 02-07-2026، الساعة 16:28 بتوقيت +0200. تقرير الفحص للمضيف `ec2-3-88-28-22.compute-1.amazonaws.com (3.88.28.22)`. المضيف متاح، بزمن استجابة 0.065 ثانية. لم تُعرض 994 منفذًا من نوع TCP تمت تصفيتها لعدم ورود استجابة. عناوين الجدول: المنفذ، الحالة، الخدمة، الإصدار.

خدمة FTP: يمنع الخادم ارتداد اتصالات FTP إلى المنافذ المنخفضة الأقل من 1025. الدخول المجهول مسموح برمز 230. حالة الخادم: متصل بالعنوان 89.6.234.42، ومسجل الدخول باسم `ftp`، ونوع النقل ASCII. لا يوجد حد لعرض نطاق الجلسة؛ مهلة الجلسة 300 ثانية. اتصال التحكم واتصالات البيانات غير مشفرة. عند بدء الجلسة كان عدد العملاء 2. وصف vsFTPd 3.0.3: «آمن وسريع ومستقر». نهاية معلومات الحالة.

المنفذان 80 و443 مفتوحان وتخدمهما Caddy؛ عنوان الصفحة «يعمل». المنفذ 113 مغلق، والخدمة ident. تتضمن الشهادة اسم الموضوع والأسماء البديلة المذكورة في التقرير، وتبدأ صلاحيتها في `2026-06-25T16:10:53` وتنتهي في `2027-06-25T16:10:53`. البيانات العشوائية في TLS لا تمثل الوقت.

على المنفذ 8000: nginx 1.27.5، وعنوان الصفحة «نظام الفوترة القديم»؛ قد يعيد الوكيل توجيه الطلبات. عُثر على مستودع Git في `3.88.28.22:8000/.git/`. وصفه: «مستودع بلا اسم؛ عدّل الملف description لتسميته...». رسالة آخر إيداع: «الإيداع الأول - تطبيق الفوترة القديم». على المنفذ 8080: Caddy وعنوان «مراقبة MegaCorp». معلومات الخدمة: نظام التشغيل Unix. اكتمل اكتشاف الخدمات؛ يُرجى الإبلاغ عن النتائج غير الصحيحة عبر `https://nmap.org/submit/`. فُحص عنوان IP واحد ومضيف واحد متاح خلال 29.75 ثانية. نص الصفحة الإسبانية في الخلفية مترجم في صفحة الأصل 2.

الشكل 1. الاستطلاع الأولي باستخدام Nmap.

أُجري فحص استطلاع باستخدام Nmap مع الخيارين `-sC` و`-sV` لتحديد الخدمات المكشوفة وإصداراتها. كشف التحليل عن منافذ مفتوحة متعددة، منها FTP (21) وHTTP (80) وHTTPS (443) وHTTP (8000) وHTTP (8080). كما اكتشف السكربت `ftp-anon` أن الخادم يسمح بالمصادقة المجهولة، وحدد الملفين `flag.txt` و`welcome.txt`، مما أظهر احتمال وجود ثغرة في الإعداد.



الشكل 2. التحقق من الوصول المجهول إلى FTP.

بعد اكتشاف الثغرة بواسطة Nmap، جرى التحقق منها يدويًا بالاتصال بخدمة FTP باسم `anonymous`. وبعد الدخول، عُرضت محتويات الخادم ونُزّل الملف `flag.txt` وفُحص محتواه بالأمر `cat`، فاستُخرج الدليل `FLAG{ftp_anonymous_access}`. أكدت هذه التجربة أن الخدمة تسمح بالوصول دون مصادقة، وأثبتت النتيجة المحددة أثناء الاستطلاع.

ترجمة رسائل لقطة الشاشة: تم الاتصال بالعنوان 3.88.28.22؛ الخادم vsFTPd 3.0.3؛ اسم المستخدم anonymous؛ تم الدخول بنجاح. نوع النظام البعيد UNIX، ويُستخدم النقل الثنائي للملفات. الاستجابة 229: الدخول في الوضع السلبي الموسع. الاستجابة 150: بدء إرسال قائمة الدليل. الاستجابة 226: اكتمل إرسال القائمة. يظهر الملفان `flag.txt` و`welcome.txt`. عند التنزيل، اسم الملف المحلي والبعيد `flag.txt`، وفُتح اتصال بيانات ثنائي لنقل 138 بايت؛ اكتمل النقل، واستُقبلت 138 بايت خلال 00:00 بمعدل 1.28 كيلوبايت/ثانية. الاستجابة 221: إلى اللقاء. يعرض الملف `FLAG{ftp_anonymous_access}` ثم: «لقد وجدت FTP مجهول الوصول. الخطوة التالية: احصر المضيفات الافتراضية على خادم الويب باستخدام `ffuf -H 'Host: FUZZ.megacorp.lab'`». نص الخلفية مترجم في صفحة الأصل 2.

خطوات إعادة الإنتاج

1. تنفيذ `nmap -sC -sV 3.88.28.22`.
2. التحقق من أن السكربت `ftp-anon` يشير إلى السماح بالوصول المجهول.
3. الاتصال باستخدام `ftp 3.88.28.22`.
4. تسجيل الدخول باسم `anonymous`.
5. عرض محتويات الخادم بالأمر `ls`.
6. تنزيل `flag.txt` باستخدام `get flag.txt`.
7. عرض محتواه بالأمر `cat flag.txt` والتحقق من `FLAG{ftp_anonymous_access}`.

المعالجة الموصى بها

- تعطيل الوصول المجهول إلى FTP.
- السماح بالمصادقة للمستخدمين المصرح لهم فقط.
- تقييد الوصول إلى الخدمة بواسطة جدار ناري أو قوائم التحكم في الوصول.
- استبدال FTP ببروتوكولات مشفرة مثل SFTP أو FTPS.

المراجع

- CWE-306: غياب المصادقة لوظيفة حرجة.
- OWASP ASVS 4.0 - V14: الإعداد الآمن.
- CIS Controls v8: إدارة الإعدادات الآمنة.

تفصيل صغير: توجد إشارة إرشادية في مخرجات `cat flag.txt`... [1]

[F-02] كشف المعلومات عبر robots.txt

الحقل	القيمة
المعرّف	F-02
درجة الخطورة	منخفضة
CVSS 3.1	`3.7 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)` (اختياري)
الأصل المتأثر	www.megacorp.lab (/robots.txt)
الفئة	كشف المعلومات
الحالة	مفتوحة

[1] «الخطوة التالية: احصر المضيفات الافتراضية على خادم الويب باستخدام `ffuf -H 'Host: FUZZ.megacorp.lab'`». لا تمثل هذه الإشارة جزءًا من دليل الثغرة. سأستخدمها فقط للبدء في النتيجة التالية، أي حصر المضيفات الافتراضية.

الوصف

يكشف الملف `robots.txt` معلومات عن البنية الداخلية للتطبيق، إذ يحدد أدلة حساسة هي `/admin` و`/backup` و`/uploads`، لا ينبغي أن تكون عامة. كما يتضمن تعليقًا يوضح وجود مضيف افتراضي لبيئة ما قبل الإنتاج، فيقدم معلومات مفيدة لمرحلة الاستطلاع.

الأثر

رغم أن `robots.txt` لا يمنح الوصول بحد ذاته، فإنه يسهّل استطلاع الهدف، ويتيح للمهاجم تحديد موارد قد تكون حساسة ونقاط دخول جديدة، مما يقلل الجهد اللازم لمتابعة التدقيق أو الهجوم.

الأدلة / إثبات المفهوم

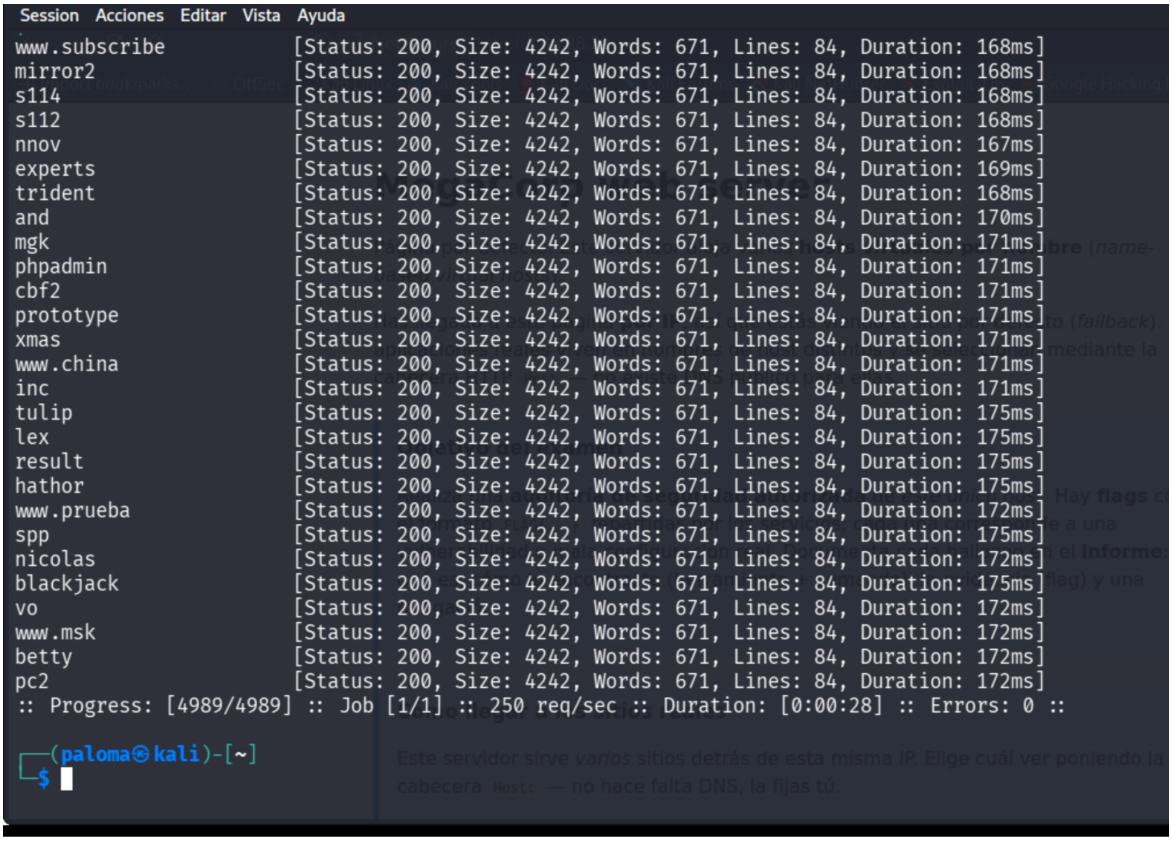
```
curl -H "Host: www.megacorp.lab" http://3.88.28.22/robots.txt
```

المخرجات المهمة:

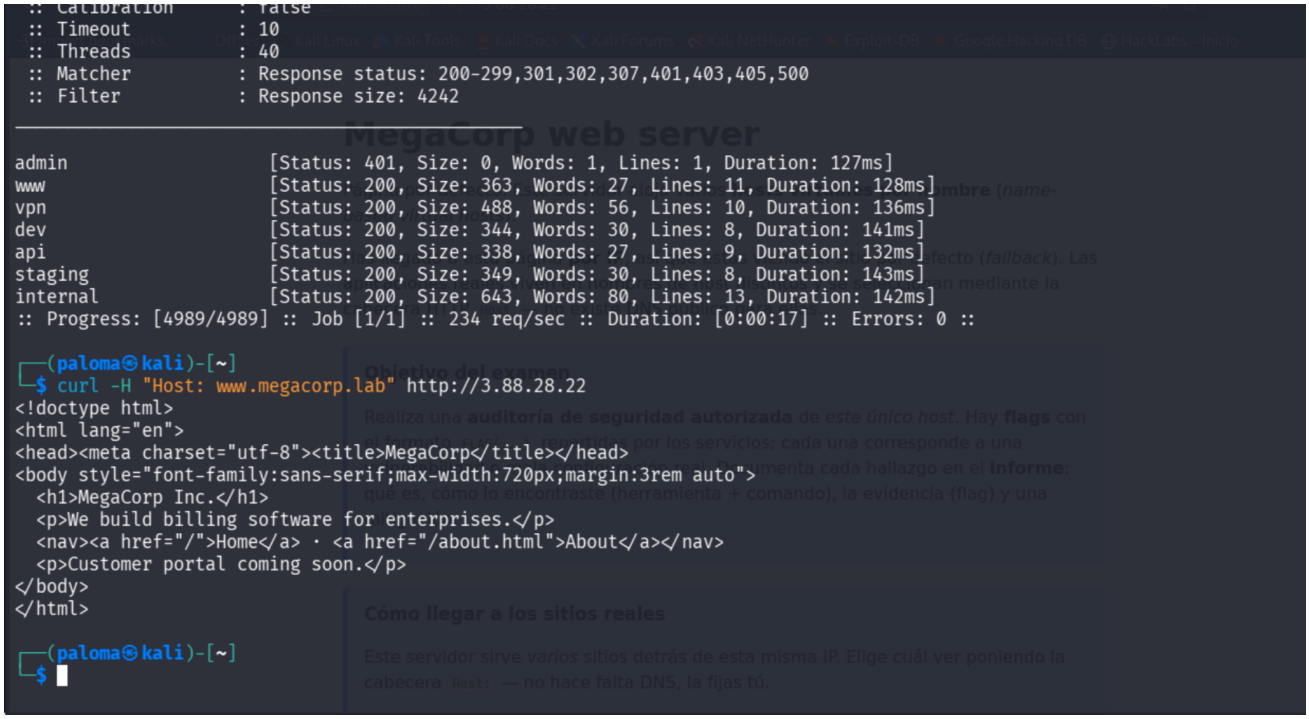
```
User-agent: *
Disallow: /admin
Disallow: /backup
Disallow: /uploads
# staging area moved to a separate virtual host
```

الترجمة: تُمنع جميع روبوتات الفهرسة من فهرسة المسارات `/admin` و`/backup` و`/uploads`. التعليق: «نُقلت بيئة ما قبل الإنتاج إلى مضيف افتراضي مستقل».

الدليل:



ترجمة عناوين المخرجات: حالة الاستجابة، الحجم، عدد الكلمات، عدد الأسطر، المدة. تعرض الأسماء المرشحة الحالة 200 والحجم 4242 و671 كلمة و84 سطرًا، مع زمن الاستجابة بالمللي ثانية. التقدم: 4989/4989؛ المهمة 1/1؛ 250 طلبًا/ثانية؛ المدة 0:00:28؛ الأخطاء 0. قوائم الطرفية: الجلسة، الإجراءات، تحرير، عرض، مساعدة. النص المتكرر في خلفية الصفحة مترجم في صفحة الأصل 2.



الشكل 3. حصر المضيفات الافتراضية باستخدام FFUF.

استُخدمت الأداة FFUF في هذه المرحلة لتنفيذ تخمين شامل لقيم ترويسة HTTP المسماة `Host`، بهدف تحديد المضيفات الافتراضية المختلفة المضبوطة على خادم الويب. وبعد تصفية الاستجابة الخاصة بالصفحة الافتراضية باستخدام `-fs 4242`، أمكن اكتشاف مضيفات صحيحة، منها `www` و`dev` و`api` و`staging` و`internal` و`vpn` و`admin`. تشكل هذه المضيفات سطح هجوم الخادم، وستُحلل في مراحل التدقيق التالية. أتاح هذا الاكتشاف تحديد تطبيقات وخدمات لا يمكن الوصول إليها إلا باستخدام ترويسة `Host`، كما ورد في تعليمات التمرين.

ترجمة إعدادات المخرجات: المعايرة معطلة؛ المهلة 10؛ عدد خيوط التنفيذ 40؛ اختيار حالات الاستجابة 200-299,301,302,307,401,403,405,500؛ تصفية حجم الاستجابة 4242.

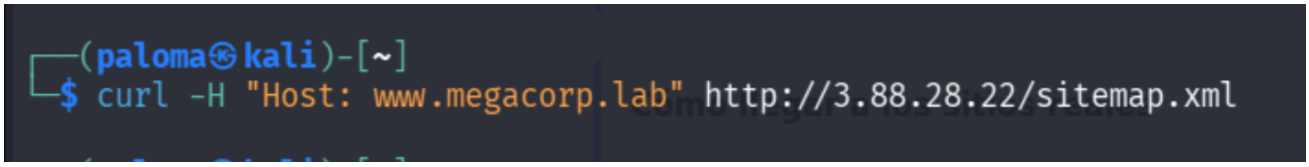
المضيف	الحالة	الحجم	الكلمات	الأسطر	المدة
admin	401	0	1	1	127 ms
www	200	363	27	11	128 ms
vpn	200	488	56	10	136 ms
dev	200	344	30	8	141 ms
api	200	338	27	9	132 ms
staging	200	349	30	8	143 ms
internal	200	643	80	13	142 ms

اكتمل 4989/4989؛ المهمة 1/1؛ المعدل 234 طلبًا/ثانية؛ المدة 0:00:17؛ الأخطاء 0. نص الموقع: «شركة MegaCorp. نطوّر برمجيات فوترة للمؤسسات». روابط التنقل: «الرئيسية» و«حول الشركة». «بوابة العملاء قريبًا».



الشكل 4. حصر المعلومات الحساسة عبر robots.txt.

بعد تحديد المضيف الافتراضي `www.megacorp.lab`، طُلب الملف `robots.txt` باستخدام ترويسة `Host` المناسبة. وُجدت فيه أدلة محددة على أنها غير قابلة للفهرسة (`/admin` و`/backup` و`/uploads`)، إضافةً إلى تعليق يكشف نقل بيئة ما قبل الإنتاج إلى مضيف افتراضي مستقل. يشكل ذلك تسربًا للمعلومات لأنه يزود المدقق بمسارات وخدمات محتملة لمتابعة الحصر وتوسيع سطح هجوم الهدف. نص الاستجابة في اللقطة مترجم في صفحة الأصل 14.



الشكل 5. التحقق من وجود الملف sitemap.xml.

ضمن مرحلة حصر موارد الويب، جرت محاولة للوصول إلى الملف `sitemap.xml` على المضيف الافتراضي `www.megacorp.lab` باستخدام `curl`. لم يُرجع الطلب محتوى أو معلومات مهمة، فاستُنتج أن المورد غير متاح أو غير مضبوط على الخادم. أتاح ذلك استبعاد مسار الحصر هذا ومتابعة التدقيق باستخدام مصادر أخرى، مثل `robots.txt` والمضيفات الافتراضية المكتشفة سابقًا.

رمز الإثبات المستخرج: لا ينطبق [2].

خطوات إعادة الإنتاج

1. اكتشاف المضيف الافتراضي `www.megacorp.lab`.
2. طلب المورد `/robots.txt`.
3. تحليل الأدلة والتعليقات المكشوفة.

المعالجة الموصى بها

- تجنب التعليقات التي تكشف معلومات عن البنية التحتية.
- عدم استخدام `robots.txt` لإخفاء الموارد الحساسة.
- تقييد الوصول إلى الأدلة الإدارية باستخدام المصادقة وضوابط الوصول المناسبة.

المراجع

- OWASP WSTG: جمع المعلومات.
- CWE-200: كشف معلومات حساسة لجهة غير مخولة.

> [2] لماذا لا ينطبق رمز إثبات على robots.txt؟ لأن كل رمز يقابل ثغرة حقيقية أو إعدادًا غير سليم. استُخرج من FTP الرمز `FLAG{ftp_anonymous_access}`، مما يؤكد أن الوصول المجهول إلى FTP نتيجة مقصودة في التمرين. أما robots.txt فلا يتضمن أي رمز، بل هو مجرد «إشارة إرشادية» لمتابعة التدقيق.

[F-03] كشف معلومات حساسة من بيئة ما قبل الإنتاج (Staging)

الحقل	القيمة
المعرّف	F-03
درجة الخطورة	متوسطة
CVSS 3.1	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N) (اختياري)
الأصل المتأثر	staging.megacorp.lab
الفئة	كشف المعلومات
الحالة	مفتوحة

الوصف

اكتُشفت أثناء حصر المضيفات الافتراضية بيئة ما قبل الإنتاج `staging.megacorp.lab`. وعند الوصول إليها، ظهرت معلومات داخلية توضح أنها نسخة ما قبل الإنتاج لتطبيق الفوترة، وأن عرض محتويات الأدلة مفعّل، وأن نسخة احتياطية من قاعدة البيانات موجودة في دليل الويب. لا ينبغي أن تكون هذه المعلومات متاحة من الخارج لأنها تمنح المهاجم إشارات بالغة القيمة.

الأثر

يسهّل إفشاء المعلومات الداخلية المراحل التالية للهجوم، إذ يكشف تفاصيل عن البنية التحتية وبيئة التطوير والموارد المحتمل حساسيتها. يمكن للمهاجم استخدام ذلك لتحديد نسخ احتياطية أو شيفرة مصدرية أو إعدادات مكشوفة، ثم اختراق التطبيق لاحقًا.

الأدلة / إثبات المفهوم

الأوامر المستخدمة

```
curl -H "Host: staging.megacorp.lab" http://3.88.28.22

ffuf \
-u http://3.88.28.22/FUZZ \
-H "Host: staging.megacorp.lab" \
-w /usr/share/seclists/Discovery/Web-Content/raft-small-files.txt \
-e .sql,.zip,.bak,.old,.gz,.tar,.tgz,.db,.sqlite,.sqlite3,.7z
```

المخرجات المهمة

```
Pre-production mirror of the billing app.
Directory listing is on.
Someone dumped a database backup in the web root again.
```

الترجمة:

> نسخة ما قبل الإنتاج من تطبيق الفوترة. عرض محتويات الأدلة مفعّل. وضع أحدهم مجددًا نسخة احتياطية من قاعدة البيانات في جذر الويب.

أُجري أيضًا حصر للملفات باستخدام `ffuf`، دون العثور في هذه المرحلة على النسخة الاحتياطية التي أشار إليها الخادم.

```
┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22
<!doctype html>
<html lang="en"><head><meta charset="utf-8"><title>staging.megacorp.lab</title></head>
<body style="font-family:sans-serif;max-width:720px;margin:3rem auto">
  <h1>Staging</h1>
  <p>Pre-production mirror of the billing app. Directory listing is on.</p>
  <p>Someone dumped a database backup in the web root again.</p>
</body></html>

┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22 | head -40
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100   349 100   349    0     0  1639      0  --:--:-- --:--:-- --:--:--  1646
<!doctype html>
<html lang="en"><head><meta charset="utf-8"><title>staging.megacorp.lab</title></head>
<body style="font-family:sans-serif;max-width:720px;margin:3rem auto">
  <h1>Staging</h1>
  <p>Pre-production mirror of the billing app. Directory listing is on.</p>
  <p>Someone dumped a database backup in the web root again.</p>
</body></html>

┌──(paloma㉿kali)-[~]
└─$
```

الشكل 5. الوصول إلى المضيف الافتراضي staging.megacorp.lab باستخدام ترويسة Host وأداة curl. تكشف استجابة الخادم أنه بيئة ما قبل الإنتاج للتطبيق، وتوضح تفعيل عرض محتويات الأدلة ووجود نسخة احتياطية من قاعدة البيانات في دليل الويب؛ فتقدم معلومات حساسة مفيدة لمتابعة التدقيق.

عنوان الصفحة: «بيئة ما قبل الإنتاج»، ثم النص المترجم في صفحة الأصل 18. تعرض إحصاءات نقل cURL إجمالي البيانات والمستلم والمرسل ومتوسط السرعة والوقت والوقت المتبقي والسرعة الحالية. استُلم 349 بايت بنسبة 100%، وبسرعة 1639 بايت/ثانية.

```
┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22/backup.sql

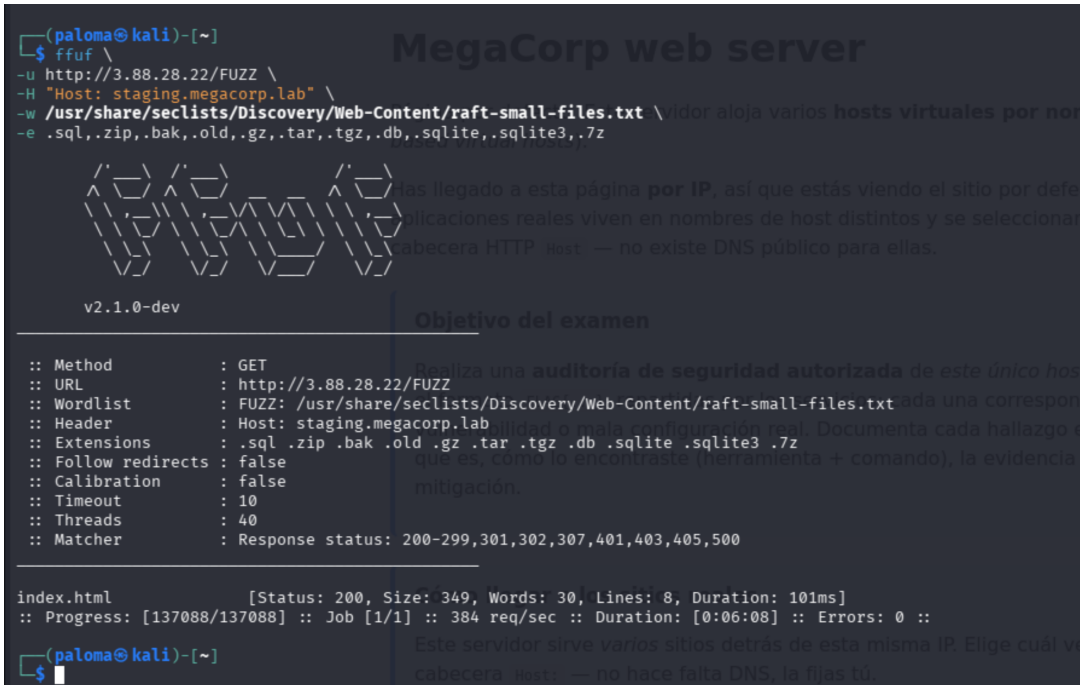
┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22/backup.zip

┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22/backup.tar.gz

┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22/database.sql

┌──(paloma㉿kali)-[~]
└─$
```

الشكل 6. الفحص اليدوي باستخدام curl لأسماء ملفات النسخ الاحتياطية التي توحي بها بيئة ما قبل الإنتاج: `backup.sql` و`backup.zip` و`backup.tar.gz` و`database.sql`. أُجري هذا الفحص للتحقق مما إذا كانت هناك نسخة احتياطية متاحة للعامة عبر خادم الويب وتحتوي معلومات حساسة.



الشكل 7. تشغيل ffuf على المضيف الافتراضي staging.megacorp.lab باستخدام قائمة كلمات للملفات وامتدادات النسخ الاحتياطية الشائعة مثل `.sql` و`.zip` و`.bak` و`.gz` و`.tar`.. كان الهدف تحديد ملفات حساسة مكشوفة للعامة. لم يُعثر أثناء الفحص إلا على `index.html`، ولذلك لم تُكتشف نسخ احتياطية متاحة تحت الأسماء الأكثر شيوعًا.

ترجمة الإعدادات والنتيجة في اللقطة: الإصدار ffuf v2.1.0-dev؛ الطريقة GET؛ العنوان `http://3.88.28.22/FUZZ`؛ قائمة الكلمات `/usr/share/seclists/Discovery/Web-Content/raft-small-files.txt`؛ الترويسة `Host: staging.megacorp.lab`؛ الامتدادات `.sql .zip .bak .old .gz .tar .tgz .db .sqlite .sqlite3 .7z`.. تتبع إعادة التوجيه معطل؛ المعايرة معطلة؛ المهلة 10؛ خيوط التنفيذ 40. حالات الاستجابة المختارة -200 299,301,302,307,401,403,405,500. نتيجة `index.html`: الحالة 200، الحجم 349، الكلمات 30، الأسطر 8، المدة 101 مللي ثانية. اكتمل 137088/137088؛ المهمة 1/1؛ 384 طلبًا/ثانية؛ المدة 0:06:08؛ الأخطاء 0.

رمز الإثبات المستخرج: لا ينطبق.

خطوات إعادة الإنتاج

1. اكتشاف المضيف الافتراضي `staging.megacorp.lab` عن طريق حصر المضيفات الافتراضية.
2. الوصول إلى المضيف باستخدام ترويسة `Host`.
3. ملاحظة المعلومات الداخلية التي تعرضها الصفحة.
4. حصر ملفات النسخ الاحتياطية المحتملة لمحاولة تحديد الموارد المذكورة.

المعالجة الموصى بها

- إلغاء الإتاحة العامة لبيئة ما قبل الإنتاج.
- عدم عرض الرسائل الداخلية أو رسائل التصحيح في التطبيقات المتاحة من الإنترنت.
- تعطيل عرض محتويات الأدلة.

- حفظ النسخ الاحتياطية خارج الدليل العام لخادم الويب.

المراجع

- CWE-200: كشف معلومات حساسة لجهة غير مخولة.
- OWASP Top 10 2021 - A05: أخطاء إعداد الأمان.
- دليل OWASP لاختبار أمن الويب WSTG: جمع المعلومات.

[F-04] كشف نسخة احتياطية لقاعدة البيانات في بيئة ما قبل الإنتاج

الحقل	القيمة
المعرّف	F-04
درجة الخطورة	مرتفعة
CVSS 3.1	`7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)`
الأصل المتأثر	staging.megacorp.lab (/db_backup.sql)
الفئة	كشف معلومات حساسة / نسخة احتياطية متاحة للعامة
الحالة	مفتوحة

الوصف

تحققنا أثناء التدقيق من أن البيئة `staging.megacorp.lab` تكشف نسخة احتياطية من قاعدة البيانات باسم `db_backup.sql` يمكن الوصول إليها دون مصادقة. يتضمن الملف

معلومات حساسة، مثل بنية قاعدة البيانات والمستخدمين وبيانات اعتماد يُعاد استخدامها وملاحظات داخلية عن بيئة التطوير.

الأثر

قد يحصل المهاجم على معلومات حساسة عن التطبيق، ويعيد استخدام بيانات الاعتماد في خدمات أخرى، ويتعرف إلى بنية قاعدة البيانات، ويستخدم هذه المعلومات لإعداد هجمات لاحقة. كما يكشف الملف نفسه معلومات إضافية عن خدمات داخلية أخرى، مما يسهّل الحركة الجانبية في البنية التحتية.

الأدلة / إثبات المفهوم

الأمر المستخدم

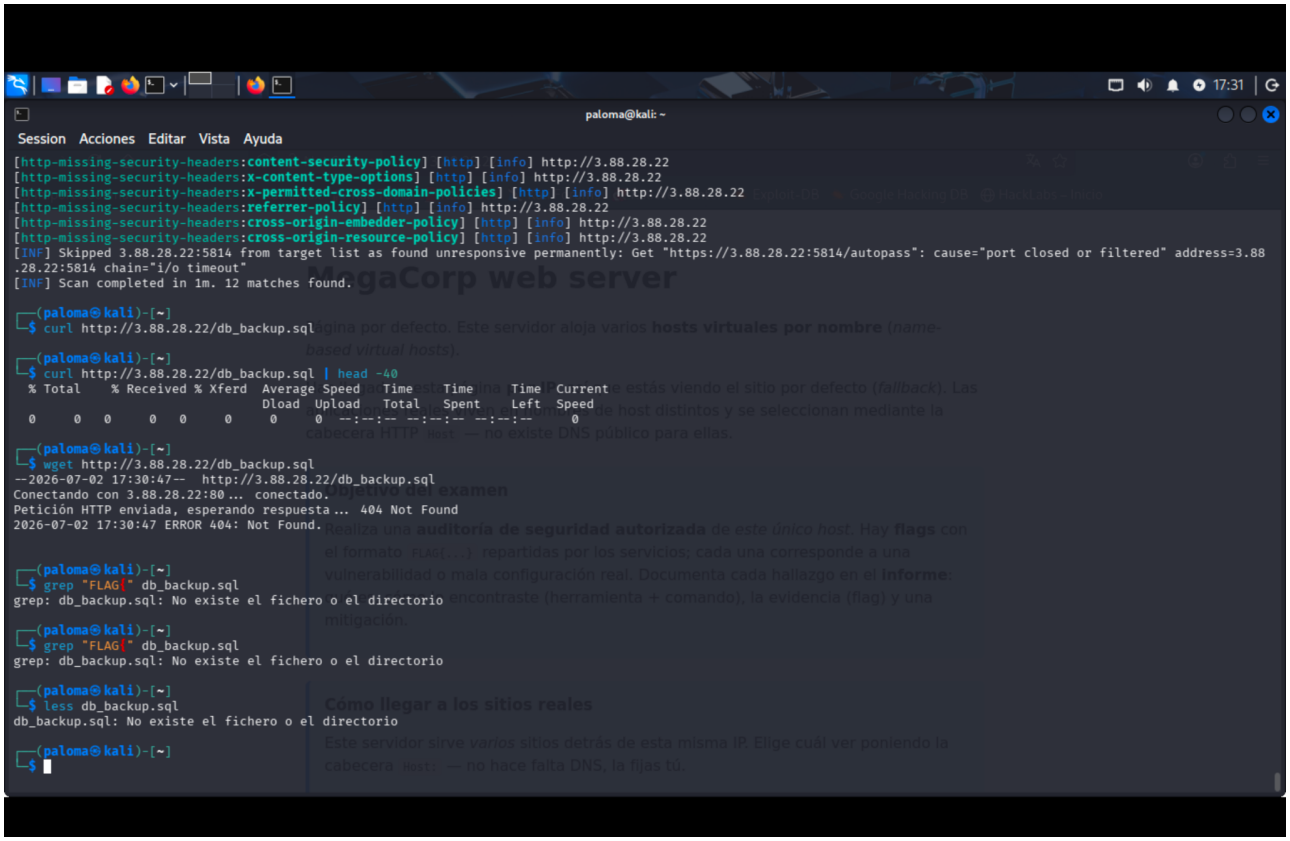
```
curl -H "Host: staging.megacorp.lab" http://3.88.28.22/db_backup.sql
```

المخرجات المهمة

```
-- MegaCorp billing DB - staging backup
FLAG{staging_sql_backup}
Note: Same DB password as dev (Sup3rDevPassw0rd!).
Credential reuse.
Cache: secrets are kept in the unauthenticated Redis node on port 6379.
```

الترجمة:

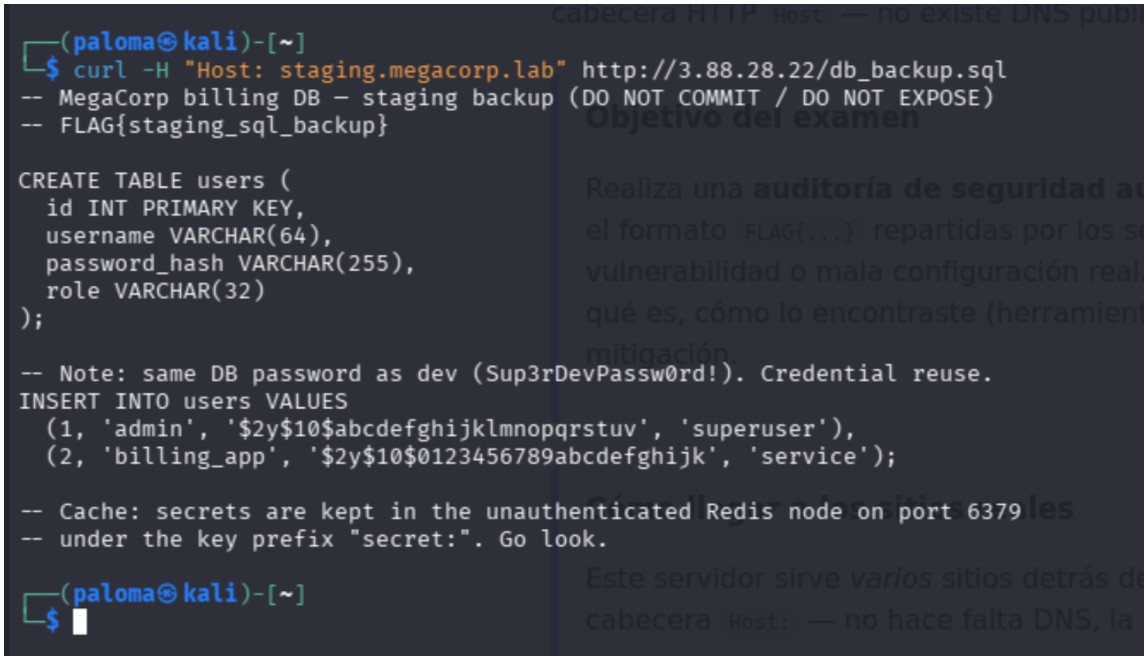
> قاعدة بيانات الفوترة لدى MegaCorp - نسخة احتياطية لبيئة ما قبل الإنتاج. `FLAG{staging_sql_backup}`. ملاحظة: كلمة مرور قاعدة البيانات هي نفسها في بيئة التطوير (`Sup3rDevPassw0rd!`). بيانات الاعتماد معاد استخدامها. الذاكرة المؤقتة: تُحفظ الأسرار في عقدة Redis غير المحمية بالمصادقة على المنفذ 6379.



ترجمة الرسائل الإضافية: ترويسات أمان HTTP غير الموجودة هي `content-security-policy` و`x-content-type-options` و`x-permitted-cross-domain-policies` و`referrer-policy` و`cross-origin-embedder-policy` و`cross-origin-resource-policy`؛ التصنيف معلوماتي. استُبعد 3.88.28.22:5814 من الأهداف لأنه لا يستجيب باستمرار؛ الطلب إلى `https://3.88.28.22:5814/autopass`؛ السبب: المنفذ مغلق أو مصفّى، وانتهت مهلة الإدخال والإخراج. اكتمل الفحص خلال دقيقة وعُثر على 12 تطابقًا.

إحصاءات نقل cURL صفرية. رسائل Wget: في 2026-07-02 17:30:47، تم الاتصال بالعنوان 3.88.28.22:80؛ أُرسل طلب HTTP، وفي انتظار الاستجابة؛ الخطأ `404 Not Found` أي «غير موجود». محاولتا `grep` والأمر `less` للملف `db_backup.sql`: «لا يوجد مثل هذا الملف أو الدليل». قوائم الطرفية والخلفية مترجمة سابقًا.

الشكل 8. الفحص الأولي للملف المحتمل db_backup.sql الذي اكتشفته Nuclei. أُجريت أولًا اختبارات متعددة باستخدام `curl` و`wget` و`grep` و`less` على المضيف الافتراضي، فأعادت الخطأ `404 Not Found` أو أشارت إلى عدم وجود الملف. أتاح ذلك استبعاد افتراض وصول غير صحيح، والاستنتاج بأن المورد متاح فقط من المضيف الافتراضي المناسب باستخدام الترويسة `Host: staging.megacorp.lab`.



الشكل 9. الوصول الناجح إلى db_backup.sql في بيئة staging.megacorp.lab باستخدام ترويسة Host.

تحققنا من أن النسخة الاحتياطية مكشوفة للعامة وتتضمن معلومات حساسة، منها `FLAG{staging_sql_backup}` وإشارات إلى إعادة استخدام بيانات الاعتماد وإشارة إلى خدمة Redis دون مصادقة، مما يؤكد انكشاف معلومات بالغة الأهمية.

ترجمة النص والتعليقات في اللقطة: «قاعدة بيانات فوترة MegaCorp - نسخة احتياطية لبيئة ما قبل الإنتاج (لا تُضمّن في الإيداعات / لا تكشفها)». يلي ذلك رمز الإثبات وشيفرة SQL لإنشاء جدول `users` بحقوله `id` و`username` و`password_hash` و`role`، وإدراج المستخدم `admin` بدور `superuser` والمستخدم `billing_app` بدور `service`. ملاحظة: «كلمة مرور قاعدة البيانات هي نفسها في بيئة التطوير (`Sup3rDevPassw0rd!`). إعادة استخدام بيانات الاعتماد». «الذاكرة المؤقتة: تُحفظ الأسرار في عقدة Redis دون مصادقة على المنفذ 6379، تحت بادئة المفاتيح `secret:`. ابحث هناك». أُبقيت الأسماء وأنواع البيانات وقيم التجزئة وبيانات SQL في لقطة الأصل.

رمز الإثبات المستخرج

```
FLAG{staging_sql_backup}
```

خطوات إعادة الإنتاج

1. اكتشاف `staging.megacorp.lab` عن طريق حصر المضيفات الافتراضية.
2. الوصول إلى `db_backup.sql` باستخدام ترويسة `Host` المناسبة.
3. التحقق من أن الخادم يعيد المحتوى الكامل للنسخة الاحتياطية مع رمز الإثبات.

المعالجة الموصى بها

- إزالة النسخ الاحتياطية فورًا من دليل الويب.
- تقييد الوصول إلى بيئة ما قبل الإنتاج بالمصادقة أو تصفية الشبكة.
- تجنب إعادة استخدام بيانات الاعتماد بين البيئات.
- مراجعة انكشاف الملفات الحساسة دوريًا واستبعاد النسخ الاحتياطية من خادم الويب.

المراجع

- CWE-530: كشف ملف نسخة احتياطية خارج نطاق التحكم المصرح به.
- OWASP Top 10 2021 - A05: أخطاء إعداد الأمان.
- دليل OWASP للاختبار: اختبار تسرب المعلومات.

[F-05] مثيل Redis متاح دون مصادقة

الحقل	القيمة
المعرّف	F-05
درجة الخطورة	مرتفعة
CVSS 3.1	8.8 (اختياري) `(AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L)`
الأصل المتأثر	3.88.28.22:6379 (Redis)
الفئة	كشف معلومات / خدمة دون مصادقة
الحالة	مفتوحة

الوصف

حُدد مثيل Redis يمكن الوصول إليه عبر الشبكة دون طلب مصادقة. يتيح ذلك الاستعلام بحرية عن المفاتيح المخزنة والوصول إلى معلومات حساسة، مثل أسرار التطبيق وبيانات الاعتماد.

الأثر

يمكن لمهاجم بعيد الوصول إلى معلومات سرية مخزنة في Redis، مثل رموز الإدارة وأسرار التطبيق وبيانات الاعتماد. وقد يسهّل ذلك تصعيد الامتيازات واختراق خدمات أخرى في البنية التحتية.

الأدلة / إثبات المفهوم

الأوامر المستخدمة

```
redis-cli -h 3.88.28.22 -p 6379
PING
KEYS *
KEYS secret:*
GET secret:flag
GET secret:admin_token
```

المخرجات المهمة

```
PONG
KEYS secret:*
1) "secret:admin_token"
2) "secret:flag"
GET secret:flag
FLAG{redis_unauthenticated_access}
GET secret:admin_token
mc_live_8f2a9d1c7b6e4a3f
```



الشكل 10. الوصول إلى مثيل Redis دون مصادقة واسترجاع معلومات حساسة.

يوضح الشكل 10 اتصالنا بخدمة Redis باستخدام `redis-cli` دون تقديم بيانات اعتماد. وبعد التحقق من الاتصال بالأمر `PING`، حصرنا المفاتيح المخزنة باستخدام `KEYS *` و`KEYS secret:*`، وقرأنا محتوياتها باستخدام `GET`. حصلنا نتيجةً لذلك على `FLAG{redis_unauthenticated_access}` ورمز إدارة، مما يؤكد أن الخدمة تكشف معلومات حساسة دون أي آلية مصادقة. يمثل ذلك خطرًا مرتفعًا، إذ يمكن للمهاجم الوصول إلى أسرار التطبيق واستخدامها لاختراق خدمات أخرى في النظام.

تظهر في المخرجات أيضًا المفاتيح `cfg:note` و`cfg:db_host` و`secret:admin_token` و`welcome` و`cfg:db_user` و`secret:flag`. هذه أسماء تقنية تُحفظ كما هي. تؤكد الاستجابة `PONG` أن الخدمة ردّت على `PING`.

رمز الإثبات المستخرج

```
FLAG{redis_unauthenticated_access}
```

خطوات إعادة الإنتاج

1. الاتصال بخدمة Redis باستخدام `redis-cli`.
2. التحقق من استجابتها دون مصادقة باستخدام `PING`.
3. حصر المفاتيح باستخدام `KEYS *` و`KEYS secret:*`.

4. قراءة محتواها باستخدام `GET secret:flag` و`GET secret:admin_token`.

المعالجة الموصى بها

- تفعيل المصادقة في Redis باستخدام `requirepass` أو قوائم ACL.
- قصر الوصول على الشبكة الداخلية أو تقييده بجدار ناري.
- تجنب حفظ أسرار بنص واضح يمكن الوصول إليه من مثيلات مكشوفة.
- استبدال رمز الإدارة المكشوف فورًا.

المراجع

- CWE-306: غياب المصادقة لوظيفة حرجة.
- CWE-200: كشف معلومات حساسة.
- OWASP Top 10 2021 - A01: خلل التحكم في الوصول.
- OWASP Top 10 2021 - A05: أخطاء إعداد الأمان.

[F-06] انكشاف مستودع Git

الحقل	القيمة
المعرّف	F-06
درجة الخطورة	مرتفعة
CVSS 3.1	`8.2 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N)`
الأصل المتأثر	http://3.88.28.22:8000/.git/
الفئة	انكشاف الشيفرة المصدرية / إفشاء معلومات حساسة
الحالة	مفتوحة

صفحة الأصل 28 من 47

الوصف

اكتُشف أن الدليل `.git` على الخادم متاح للعامة. أتاح ذلك تنزيل مستودع Git وإعادة بناء الشيفرة المصدرية للتطبيق والوصول إلى ملفات إعداد داخلية تحتوي معلومات حساسة عن البنية التحتية وتخزين الأسرار.

الأثر

يسمح انكشاف المستودع للمهاجم بفهم العمل الداخلي للتطبيق، وتحديد الثغرات، والحصول على معلومات حساسة، وإعداد هجمات لاحقة. وفي هذه الحالة، كُشف أيضًا أن أسرار التطبيق مخزنة في خادم Redis دون مصادقة.

الأدلة / إثبات المفهوم

الأوامر المستخدمة

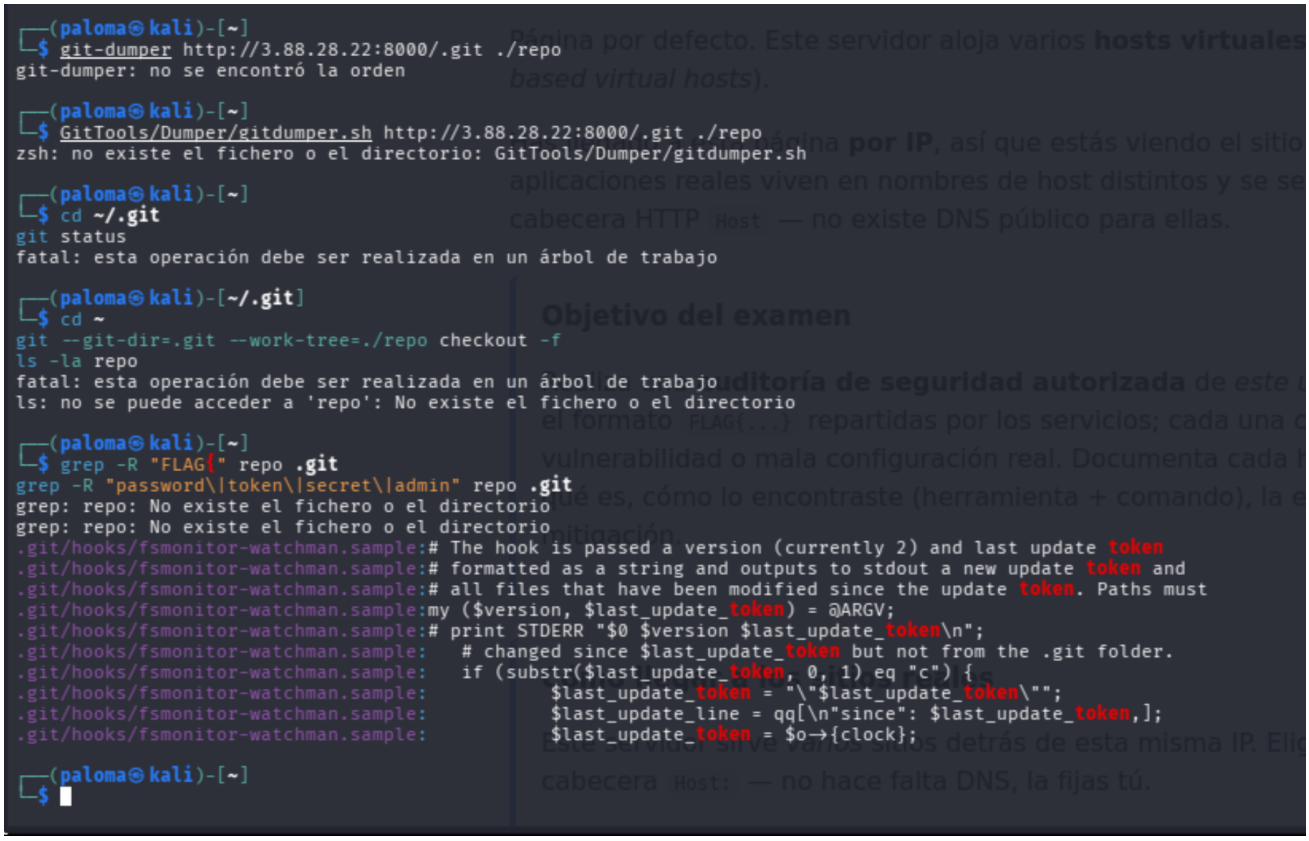
```
wget -r -np -nH http://3.88.28.22:8000/.git/
git --git-dir=$HOME/.git --work-tree=$HOME/repo checkout -f
grep -R "FLAG{" repo
grep -R "password\|secret\|token\|admin" repo
```

المخرجات المهمة

```
FLAG{git_source_disclosure}
Application secrets are cached in Redis (port 6379, no authentication).
The master flag is stored under the key: secret:flag
```

ترجمة النص: «تُخزَّن أسرار التطبيق مؤقتًا في Redis على المنفذ 6379 دون مصادقة. يُحفظ رمز الإثبات الرئيسي تحت المفتاح `secret:flag`».

انظر الشكلين 11 و12.

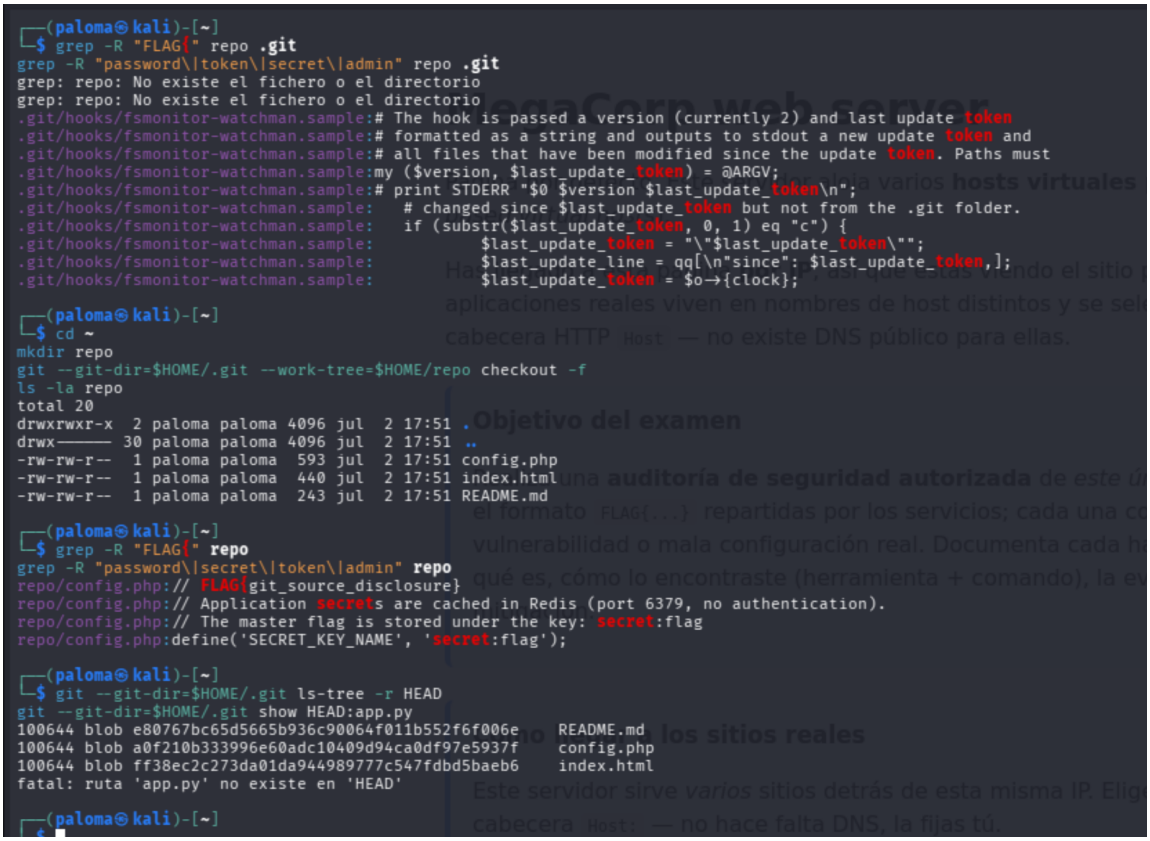


الشكل 11. محاولات إعادة بناء مستودع Git المكشوف.

تعرض اللقطة المحاولات الأولى لإعادة بناء مستودع Git المنزّل من الخادم. ورغم أن الاختبارات الأولى باستخدام `git-dumper` والبحث المباشر عن معلومات حساسة نتجت عنها أخطاء بسبب غياب شجرة عمل صالحة، فقد أتاحت التحقق من أن الدليل `.git` متاح ويتضمن الكائنات اللازمة لإعادة بناء المستودع كاملًا لاحقًا. يؤكد هذا الدليل انكشاف المستودع قبل استرجاعه النهائي.

ترجمة الرسائل في اللقطة: `git-dumper`: الأمر غير موجود. `GitTools/Dumper/gitdumper.sh`: لا يوجد مثل هذا الملف أو الدليل. الأمران `git status` و`checkout` الأولي: «خطأ فادح: يجب تنفيذ هذه العملية داخل شجرة عمل». الأمر `ls`: يتعذر الوصول إلى `repo`؛ لا يوجد مثل هذا الملف أو الدليل. الأمر `grep`: الدليل `repo` غير موجود.

تظهر في تطابقات `git/hooks/fsmonitor-watchman.sample`. التعليقات: «يُمرَّر إلى الخطاف إصدار (حاليًا 2) ورمز آخر تحديث ممثلًا كسلسلة نصية، ويُخرج إلى الخرج القياسي رمز تحديث جديدًا وجميع الملفات التي تغيرت منذ رمز التحديث السابق. يجب أن تكون المسارات...». ثم: «الملفات التي تغيرت منذ `$last_update_token`، ولكن ليس من مجلد `.git`.». بقية النص شيفرة مثال الخطاف ومتغيراته التقنية، المحفوظة في اللقطة.



ترجمة الرسائل الإضافية في اللقطة الثانية: تتكرر أخطاء عدم وجود `repo` وتعليقات الخطاف السابقة. بعد إنشاء دليل العمل، تظهر الملفات `config.php` بحجم 593 بايت و`index.html` بحجم 440 بايت و`README.md` بحجم 243 بايت؛ المالك والمجموعة `paloma`، والتاريخ 2 يوليو، الساعة 17:51؛ الإجمالي 20. تكشف مخرجات `grep` رمز الإثبات وأسرار Redis المترجمة في صفحة الأصل 28. تُدرج شجرة `HEAD` الكائنات `README.md` و`config.php` و`index.html` بأذونات 100644 ونوع `blob` وقيم التجزئة الخاصة بها. وبخصوص `app.py`: «خطأ فادح: المسار 'app.py' غير موجود في 'HEAD'».

الشكل 12. إعادة بناء مستودع Git والحصول على معلومات حساسة.

تُظهر اللقطة نجاح إعادة بناء شجرة العمل للمستودع المكشوف باستخدام `git checkout`. ثم أُجري بحث عن معلومات حساسة باستخدام `grep`، فعُثر على `FLAG{git_source_disclosure}` في `config.php`. كما كشفت الشيفرة أن التطبيق يحفظ أسرارًا في مثيل Redis دون مصادقة، وحددت أن المفتاح الرئيسي موجود تحت `secret:flag`؛ وهي معلومات أتاحت ربط النتيجة التالية بسلسلة التدقيق.

رمز الإثبات المستخرج

```
FLAG{git_source_disclosure}
```

خطوات إعادة الإنتاج

1. الوصول إلى الدليل `http://3.88.28.22:8000/.git/`.
2. تنزيل محتويات المستودع.
3. إعادة بناء شجرة العمل باستخدام Git.
4. مراجعة الملفات المسترجعة لتحديد المعلومات الحساسة.

المعالجة الموصى بها

حظر الوصول العام إلى `.git`، وإزالة أي مستودع من دليل الويب المنشور، ومراجعة الشيفرة قبل النشر لمنع انكشاف المعلومات الحساسة، واستبدال جميع بيانات الاعتماد والأسرار التي ربما كُشفت.

المراجع

- CWE-200: كشف معلومات حساسة لجهة غير مخولة.
- CWE-552: ملفات أو أدلة متاحة لأطراف خارجية.
- OWASP Top 10 2021 - A05: أخطاء إعداد الأمان.

[F-07] انكشاف الشيفرة المصدرية والمعلومات الحساسة (؟) [3]

الحقل / القيمة

> [3] ملاحظة: تمثل النتيجتان F-06 وF-07 مرحلتين من سلسلة الاستغلال نفسها. وُثقتا بصورة مستقلة للتمييز بين الثغرة الأولية، وهي انكشاف مستودع Git، وأثرها المباشر، وهو إفشاء الشيفرة المصدرية والمعلومات الحساسة، بما يسهّل التتبع وتحليل المخاطر.

الحقل	القيمة
المعرّف	F-07
درجة الخطورة	مرتفعة
CVSS 3.1	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
الأصل المتأثر	http://3.88.28.22:8000/.git/ / المستودع المعاد بناؤه
الفئة	انكشاف الشيفرة المصدرية / إفشاء الأسرار
الحالة	مفتوحة

الوصف

بعد تنزيل مستودع Git المكشوف وإعادة بنائه، تمكنا من الوصول إلى الشيفرة المصدرية للتطبيق. عُثر في `config.php` على تعليقات داخلية وإشارات إلى أسرار محفوظة في Redis ورمز إثبات، مما يؤكد انكشاف معلومات حساسة داخل الشيفرة.

الأثر

قد يحلل المهاجم الشيفرة المصدرية، ويفهم منطق التطبيق الداخلي، ويحدد الأسرار والخدمات المساعدة، ويعدّ هجمات لاحقة. وفي هذه الحالة، كشفت الشيفرة حفظ الأسرار في Redis تحت المفتاح `secret:flag`.

الأدلة / إثبات المفهوم

الأوامر المستخدمة

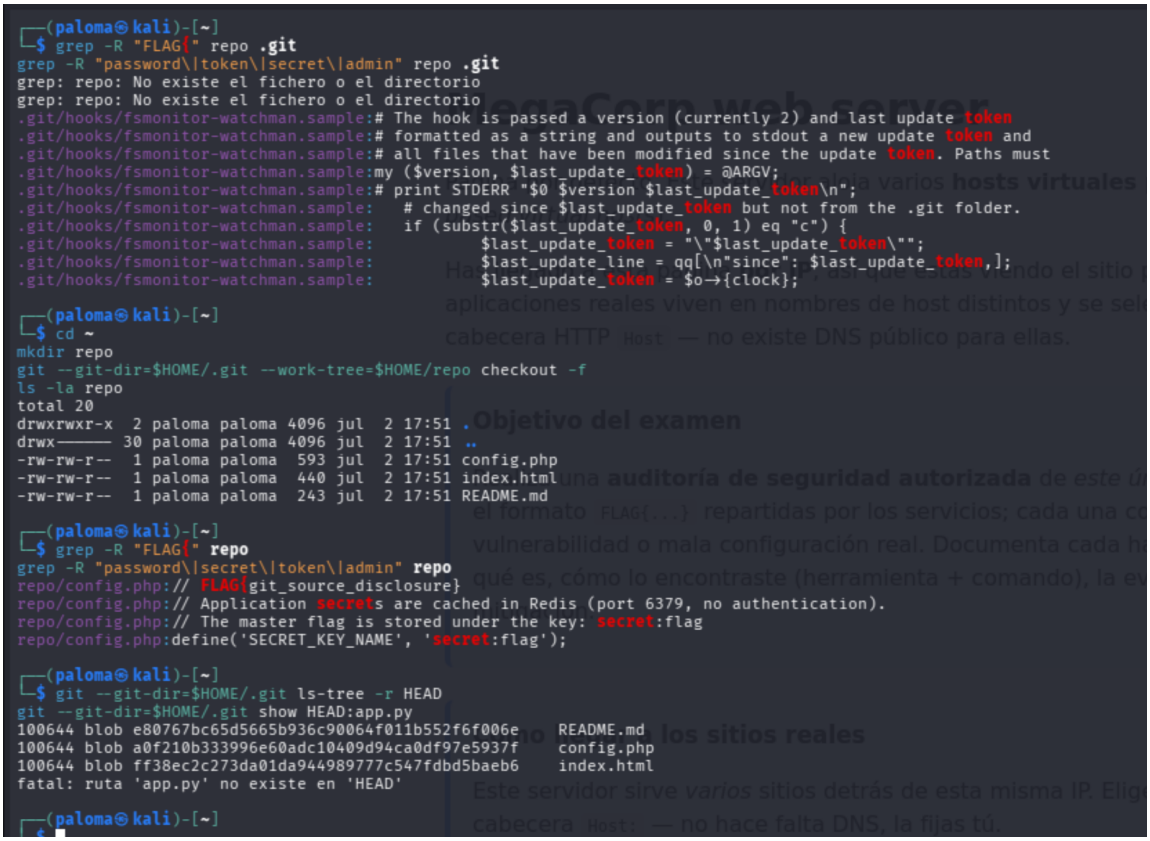
```
git --git-dir=$HOME/.git --work-tree=$HOME/repo checkout -f
grep -R "FLAG{" repo
```

```
grep -R "password\|secret\|token\|admin" repo
```

المخرجات المهمة

```
repo/config.php:// FLAG{git_source_disclosure}
repo/config.php:// Application secrets are cached in Redis (port 6379, no authentication).
repo/config.php:// The master flag is stored under the key: secret:flag
repo/config.php:define('SECRET_KEY_NAME', 'secret:flag');
```

ترجمة التعليقات: «تُخزَّن أسرار التطبيق مؤقتًا في Redis على المنفذ 6379 دون مصادقة. يُحفظ رمز الإثبات الرئيسي تحت المفتاح `secret:flag`».



الشكل 13. إعادة بناء مستودع Git المكشوف وتحليل الشيفرة المصدرية المسترجعة. تحدد عمليات البحث في الملفات معلومات حساسة وإشارات إلى أسرار التطبيق الداخلية واسم المفتاح المستخدم لحفظ رمز الإثبات في Redis، وهو `secret:flag`، والدليل `FLAG{git_source_disclosure}`؛ مما يؤكد انكشاف الشيفرة المصدرية والمعلومات السرية.

تكرر اللقطة الصورة الموجودة في صفحة الأصل 29، حيث وردت ترجمة الرسائل والتعليقات وخطأ `app.py`.

رمز الإثبات المستخرج

```
FLAG{git_source_disclosure}
```

خطوات إعادة الإنتاج

1. تنزيل الدليل `.git` المكشوف من المنفذ 8000.
2. إعادة بناء شجرة عمل المستودع.
3. البحث عن رموز الإثبات والأسرار داخل الشيفرة المصدرية.
4. مراجعة الملف `config.php`.

المعالجة الموصى بها

إزالة مستودع Git من الدليل العام، وحظر الوصول إلى `.git` على خادم الويب، ومراجعة الشيفرة لحذف الأسرار أو التعليقات الحساسة، واستبدال أي بيانات اعتماد مكشوفة.

المراجع

- CWE-200: كشف معلومات حساسة.
- CWE-540: تضمين معلومات حساسة في الشيفرة المصدرية.
- OWASP Top 10 2021 - A05: أخطاء إعداد الأمان.

F-08 - شهادة TLS موقعة ذاتيًا وكشف معلومات داخلية

الوصف

أظهر تحليل خدمة HTTPS أن الخادم يستخدم شهادة TLS موقعة ذاتيًا. كما تكشف الشهادة معلومات داخلية عن بنية MegaCorp التحتية عبر الاسم الشائع CN وامتداد الاسم البديل للموضوع SAN، فتفصح عن أسماء مضيفات داخلية متعددة.

الأدلة

الأداة المستخدمة:

```
openssl s_client -connect 3.88.28.22:443 -servername megacorp.lab </dev/null | openssl x509 -noout -text
```

النتائج المستخرجة:

```
verify error:num=18:self-signed certificate
```

الترجمة: خطأ التحقق رقم 18: شهادة موقعة ذاتيًا.

```
Subject:
CN=megacorp.lab
O=MegaCorp Internal

Subject Alternative Name:
DNS:megacorp.lab
DNS:www.megacorp.lab
DNS:dev.megacorp.lab
DNS:admin.megacorp.lab
DNS:api.megacorp.lab
DNS:internal.megacorp.lab
DNS:staging.megacorp.lab
DNS:vpn.megacorp.lab
```

ترجمة الحقول: `Subject` هو موضوع الشهادة؛ `CN` هو الاسم الشائع؛ `O` هي المؤسسة؛ و`Subject Alternative Name` هو الاسم البديل للموضوع. حُفظت قيم الأسماء دون تغيير.

الأثر

- يمنع استخدام شهادة موقعة ذاتيًا التحقق من أصالة الخادم عبر جهة إصدار شهادات موثوقة.
- يسهّل إفشاء الأسماء الداخلية أعمال الاستطلاع لمهاجم محتمل.
- قد تشكل النطاقات الفرعية المكشوفة نقطة انطلاق لتحديد خدمات إدارية أو بيئات تطوير يحتمل تعرضها للثغرات.

درجة الخطورة

متوسطة.

التوصيات

- استخدام شهادات صادرة عن جهة إصدار شهادات موثوقة CA عندما تكون الخدمة متاحة من الخارج.
- تجنب تضمين أسماء داخلية غير ضرورية في الشهادات المكشوفة.

- الفصل بين الشهادات المستخدمة في البيئات الداخلية وبيئات الإنتاج لتقليل انكشاف معلومات البنية التحتية.

F-09 - الوصول إلى مضيف افتراضي داخلي عبر حصر ترويسة Host

الوصف

حُدد الموقع `internal.megacorp.lab` أثناء حصر المضيفات الافتراضية باستخدام الأسماء المستخرجة من شهادة TLS. كان هذا المضيف، الذي يبدو مخصصًا للاستخدام الداخلي، متاحًا بمجرد تعديل ترويسة HTTP المسماة `Host`، دون أي آلية مصادقة أو تحكم في الوصول تمنع عرضه.

الأدلة

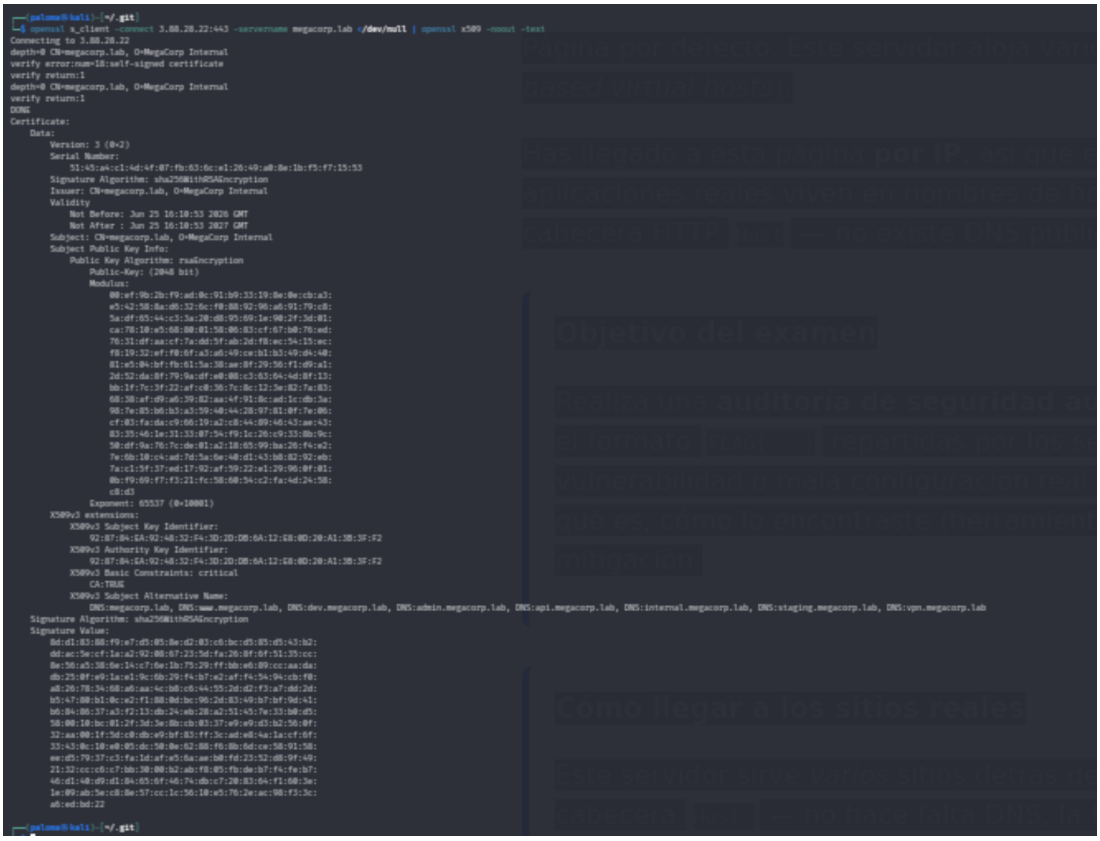
الأمر المستخدم:

```
curl -k -H "Host: internal.megacorp.lab" https://3.88.28.22
```

الاستجابة المستخرجة:

```
Restricted - staff only.
(No real access control here...)
FLAG{internal_restricted_page}
```

الترجمة: «الوصول مقيد، للموظفين فقط. (لا يوجد تحكم فعلي في الوصول هنا...)». `FLAG{internal_restricted_page}`.



ترجمة حقول الشهادة ورسائلها: الاتصال بالعنوان 3.88.28.22؛ العمق 0؛ `CN=megacorp.lab` و`O=MegaCorp Internal`؛ خطأ التحقق رقم 18: شهادة موقعة ذاتيًا؛ قيمة الإرجاع للتحقق 1؛ تم. الشهادة، البيانات: الإصدار 3 (`0x2`)، الرقم التسلسلي، خوارزمية التوقيع `sha256WithRSAEncryption`، الجهة المصدرة، الصلاحية، الموضوع، معلومات المفتاح العام للموضوع. بداية الصلاحية 25 يونيو 2026، الساعة 16:10:53 GMT، ونهايتها 25 يونيو 2027 في الساعة نفسها. خوارزمية المفتاح العام `rsaEncryption` وحجمه 2048 بت؛ معامل المفتاح والأس 65537 (`0x10001`). امتدادات X509v3: معرّف مفتاح الموضوع، ومعرّف مفتاح جهة الإصدار، والقيود الأساسية كامتداد حرج، و`CA:TRUE`؛ والاسم البديل للموضوع مع أسماء DNS المذكورة في صفحة الأصل 34. تليها خوارزمية التوقيع وقيمته. حُفظت الأرقام التسلسلية والقيم الست عشرية للمفتاح والتوقيع في لقطة الأصل.



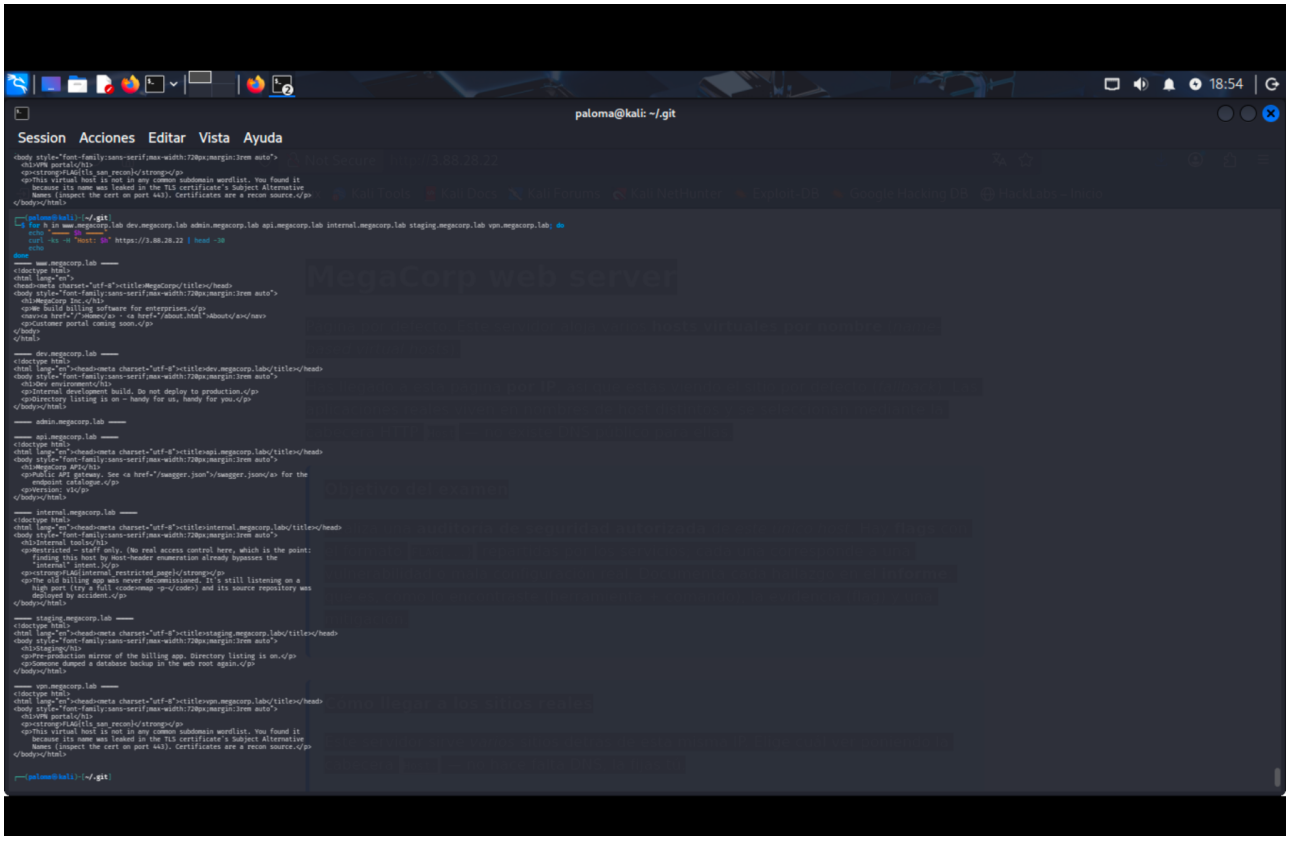
ترجمة نصوص الاستجابات في اللقطة

الأدوات الداخلية على `internal.megacorp.lab`:

> الوصول مقيد، للموظفين فقط. لا يوجد تحكم فعلي في الوصول هنا؛ وهذا هو المقصود: اكتشاف هذا المضيف بحصر ترويسة Host يتجاوز أصلًا افتراض كونه «داخليًا».
>
> `FLAG{internal_restricted_page}`
>
> لم يُخرج تطبيق الفوترة القديم من الخدمة قط. لا يزال يستمع على منفذ مرتفع؛ جرّب فحصًا كاملًا باستخدام `nmap -p-`. كما نُشر مستودع شيفرته المصدرية عن طريق الخطأ.

بوابة VPN على `vpn.megacorp.lab`:

> `FLAG{tls_san_recon}`
>
> لا يوجد هذا المضيف الافتراضي في أي قائمة كلمات شائعة للنطاقات الفرعية. عثرت عليه لأن اسمه تسرب عبر الأسماء البديلة للموضوع في شهادة TLS؛ افحص الشهادة على المنفذ 443. الشهادات مصدر للمعلومات الاستطلاعية.



ترجمة النص الإضافي الظاهر في اللقطة

- `www.megacorp.lab`: «شركة MegaCorp. نطوّر برمجيات فوترة للمؤسسات». الروابط: «الرئيسية» و«حول الشركة». «بوابة العملاء قريبًا».
- `dev.megacorp.lab`: «بيئة التطوير. نسخة داخلية لأعمال التطوير. لا تنشرها في الإنتاج. عرض محتويات الأدلة مفعّل؛ مناسب لنا ومناسب لك».
- `admin.megacorp.lab`: لا يظهر محتوى لهذا المضيف في المخرجات المعروضة.
- `api.megacorp.lab`: «واجهة API لشركة MegaCorp. بوابة API عامة. راجع `/swagger.json` للاطلاع على فهرس نقاط النهاية. الإصدار v1».
- `internal.megacorp.lab`: الاستجابة مترجمة بالكامل في صفحة الأصل 36.
- `staging.megacorp.lab`: «بيئة ما قبل الإنتاج. نسخة ما قبل الإنتاج من تطبيق الفوترة. عرض محتويات الأدلة مفعّل. وضع أحدهم مجددًا نسخة احتياطية لقاعدة البيانات في جذر الويب».
- `vpn.megacorp.lab`: الاستجابة مترجمة بالكامل في صفحة الأصل 36، وتتكرر نهايتها في أعلى اللقطة.

الشكل 14. فحص شهادة TLS للخادم.

تعرض اللقطة تحليل الشهادة الرقمية باستخدام OpenSSL. يتضح أنها موقعة ذاتيًا وتكشف معلومات داخلية عن المؤسسة، مثل النطاق `megacorp.lab` ونطاقات فرعية ضمن امتداد SAN، منها `dev.megacorp.lab` و`admin.megacorp.lab` و`internal.megacorp.lab` و`staging.megacorp.lab` و`vpn.megacorp.lab`. أتاحت هذه المعلومات تحديد مضيفات افتراضية استُخدمت لاحقًا أثناء الاستطلاع.

الشكل 15. حصر المضيفات الافتراضية عبر ترويسة Host.

توضح الصورة تنفيذ سكربت يرسل طلبات HTTP مع تعديل ترويسة `Host` لكل اسم مستخرج من شهادة TLS. يعيد الخادم محتوى مختلفًا لكل مضيف، مما يؤكد وجود عدة مواقع على عنوان IP واحد. أثناء الحصر، عُثر على `internal.megacorp.lab` و`vpn.megacorp.lab`، اللذين تضمنا معلومات حساسة واثنين من رموز إثبات التمرين.

الشكل 16. الوصول إلى المضيفات الداخلية المكتشفة.

تعرض اللقطة الوصول الفردي إلى `internal.megacorp.lab` و`vpn.megacorp.lab` باستخدام `curl` وتعديل ترويسة `Host`. استُخرج من الأول `FLAG{internal_restricted_page}`، مع معلومات عن تطبيق فوترة قديم لا يزال يعمل على منفذ مرتفع والنشر العرضي لمستودع شيفرته. ومن الثاني استُخرج `FLAG{tls_san_recon}`، مما يؤكد أن اكتشافه تحقق بفضل

المعلومات المكشوفة في شهادة TLS؛ وهو ما يوضح خطر إفشاء الأسماء الداخلية في الشهادات الرقمية.

كشفت الصفحة أيضًا معلومات إضافية عن البنية التحتية، تشير إلى وجود تطبيق فوترة قديم لا يزال يعمل على منفذ مرتفع، وإلى نشر مستودع شيفرته المصدرية عرضيًا.

الأثر

- وصول غير مصرح به إلى موارد مخصصة للاستخدام الداخلي.
- إفشاء معلومات حساسة عن البنية التحتية للمؤسسة.
- تسهيل الاستطلاع وتخطيط هجمات لاحقة عبر كشف خدمات داخلية وإعدادات غير آمنة.

درجة الخطورة

مرتفعة.

التوصيات

- تطبيق آليات مصادقة وتخويل في جميع الخدمات الداخلية.
- تقييد الوصول بتقسيم الشبكة أو قوائم ACL أو الجدار الناري.
- عدم الاعتماد على ترويسة `Host` وحدها لحماية الموارد الداخلية.
- مراجعة المضيفات الافتراضية المنشورة دوريًا لضمان عدم إتاحة البيئات الداخلية من الخارج.

النتيجة F-10 - انكشاف مستودع Git لتطبيق Legacy Billing

الوصف

حُدد أثناء تحليل خدمة HTTP المتاحة على المنفذ 8000 تطبيق باسم Legacy Billing App. أشار التطبيق نفسه إلى نشره مباشرةً من دليل عمل Git. وعند الوصول إلى `/.git/`، اتضح أن المستودع متاح بالكامل من الخارج، مما يسمح باستعراض بنيته وربما إعادة بناء الشيفرة المصدرية للتطبيق.

الأدلة

الأوامر المستخدمة:

```
curl http://3.88.28.22:8000
curl http://3.88.28.22:8000/.git/
curl http://3.88.28.22:8000/.git/HEAD
curl http://3.88.28.22:8000/.git/config
```

استُخرجت قائمة بمحتويات الدليل `.git`، بما فيها عناصر مثل:

```
HEAD
config
objects/
refs/
logs/
index
```

كما أعاد الملف `HEAD` ما يلي:

```
ref: refs/heads/master
```

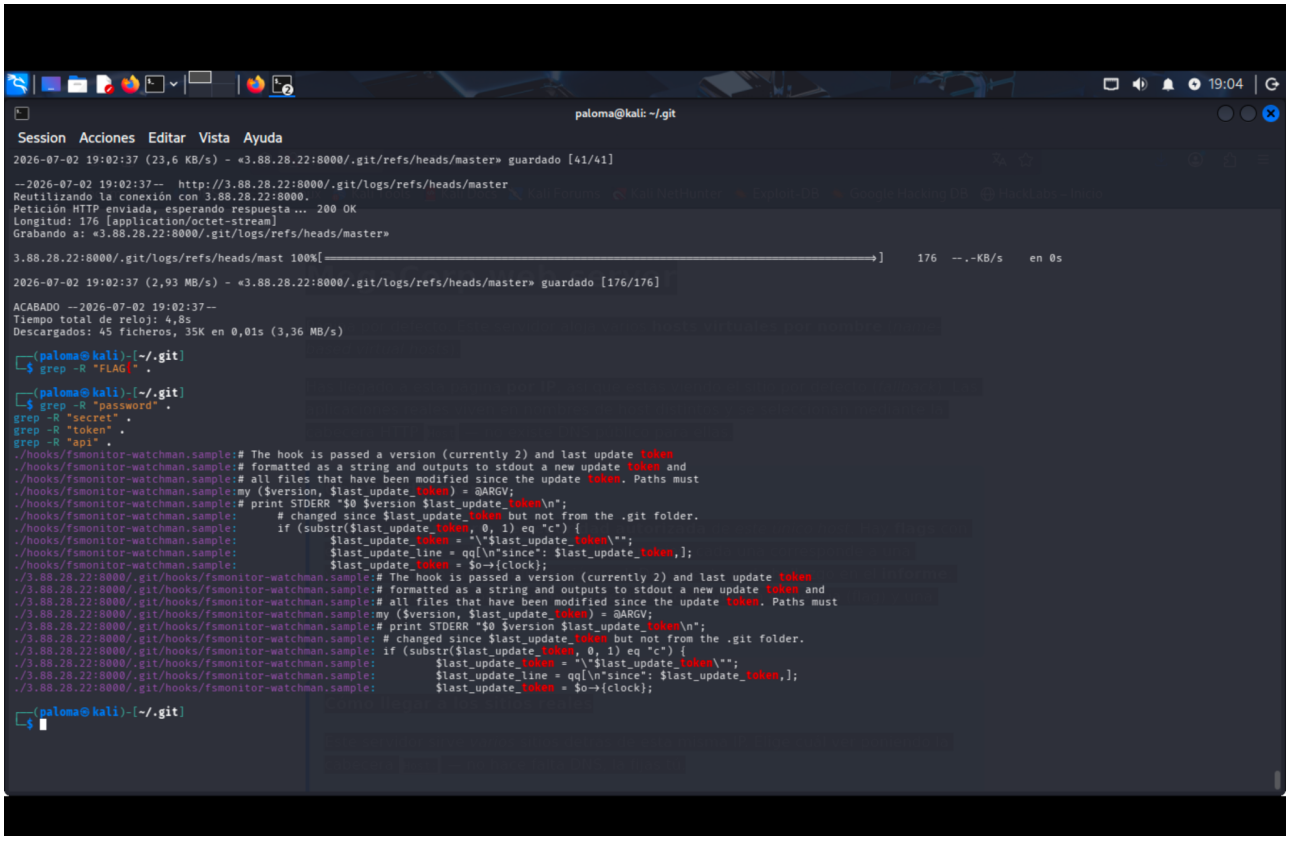
وهو ما أكد أنه مستودع Git فعّال.

الأثر

- انكشاف الشيفرة المصدرية للتطبيق.
- احتمال إفشاء بيانات اعتماد أو مفاتيح API أو معلومات حساسة.
- تسهيل تحليل الثغرات وتطوير هجمات موجهة.

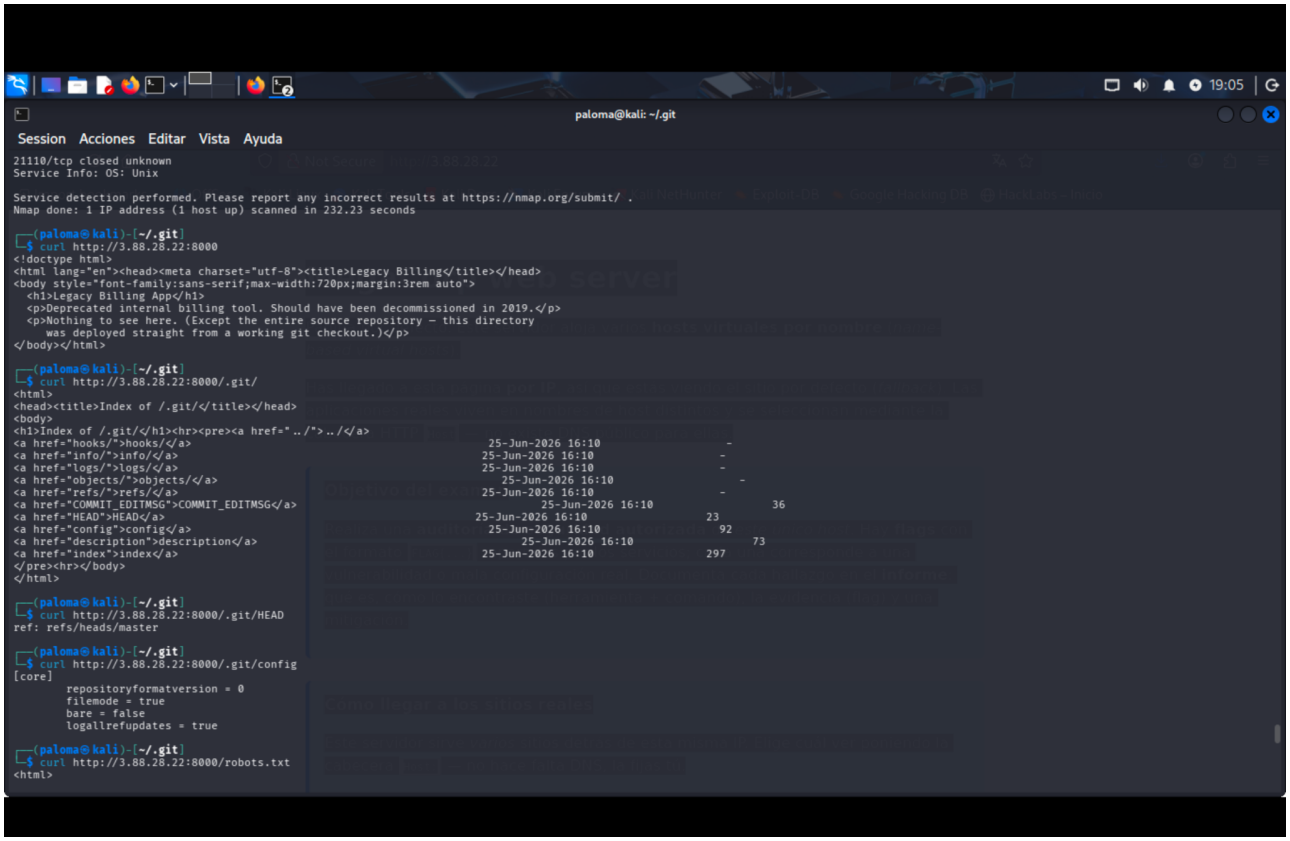
درجة الخطورة

مرتفعة.



ترجمة الرسائل في اللقطة الأولى: حُفظ الملف `3.88.28.22:8000/.git/refs/heads/master` بحجم 41/41 بايت وبسرعة 23.6 كيلوبايت/ثانية، في 2026-07-02 19:02:37. أُعيد استخدام الاتصال بالعنوان 3.88.28.22:8000. أُرسل طلب HTTP وفي انتظار الاستجابة؛ `200 OK`. الطول 176 والنوع `application/octet-stream`. الحفظ إلى `3.88.28.22:8000/.git/logs/refs/heads/master`؛ اكتمل 100%، أي 176 بايت، خلال 0 ثانية. حُفظ الملف 176/176 بايت بسرعة 2.93 ميغابايت/ثانية. اكتمل العمل في 2026-07-02 19:02:37؛ الزمن الإجمالي 4.8 ثانية؛ نُزل 45 ملفًا، بحجم 35 كيلوبايت خلال 0.01 ثانية، وبسرعة 3.36 ميغابايت/ثانية.

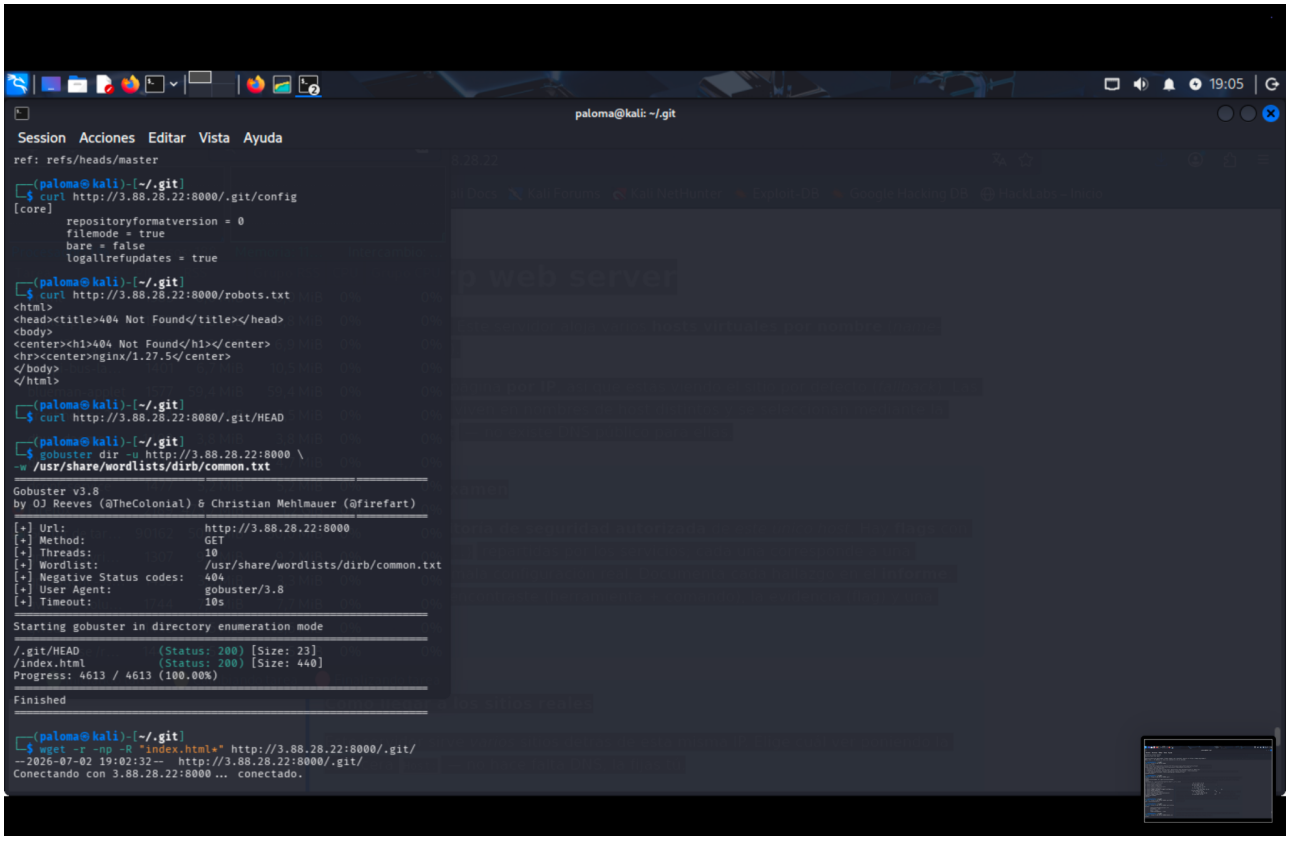
تظهر بعد ذلك عمليات البحث عن `FLAG{` و`password` و`secret` و`token` و`api`. التعليقات المتطابقة في نسختين من `fsmonitor-watchman.sample`: «يُمرَّر إلى الخطاف إصدار (حاليًا 2) ورمز آخر تحديث ممثلًا كسلسلة نصية، ويُخرج إلى الخرج القياسي رمز تحديث جديدًا وجميع الملفات المتغيرة منذ الرمز السابق. يجب أن تكون المسارات...»؛ «الملفات المتغيرة منذ `$last_update_token`، ولكن ليس من مجلد `.git`.». حُفظت شيفرة مثال الخطاف دون ترجمة.



ترجمة الرسائل في اللقطة الثانية: المنفذ `21110/tcp` مغلق والخدمة غير معروفة. معلومات الخدمة: نظام التشغيل Unix. اكتمل اكتشاف الخدمات؛ يُرجى الإبلاغ عن النتائج غير الصحيحة عبر `https://nmap.org/submit/`. اكتمل Nmap: فُحص عنوان IP واحد ومضيف واحد متاح خلال 232.23 ثانية.

تطبيق الفوترة القديم: «أداة فوترة داخلية متقادمة، كان ينبغي إخراجها من الخدمة في 2019. لا يوجد ما يستحق المشاهدة هنا؛ باستثناء مستودع الشيفرة المصدرية بأكمله، فهذا الدليل نُشر مباشرةً من نسخة عمل Git».

قائمة محتويات /.git/: تظهر الأدلة `hooks/` و`info/` و`logs/` و`objects/` و`refs/` والملفات `COMMIT_EDITMSG` و`HEAD` و`config` و`description` و`index`، بتاريخ 25 يونيو 2026، الساعة 16:10. أحجام الملفات على الترتيب 36 و23 و92 و73 و297 بايت. يشير `HEAD` إلى `refs/heads/master`. إعدادات `[core]`: إصدار صيغة المستودع 0؛ تفعيل مراعاة نمط الملفات؛ المستودع ليس من نوع bare؛ تفعيل تسجيل جميع تحديثات المراجع. تظهر بعدها بداية الاستجابة لطلب `robots.txt`.



ترجمة الرسائل الإضافية في اللقطة: تتكرر قيمة HEAD وإعدادات Git. يعيد طلب robots.txt الخطأ 404 Not Found أي «404: غير موجود»، والخادم nginx/1.27.5. يلي ذلك فحص .git/HEAD على المنفذ 8080 وتشغيل Gobuster v3.8 من إعداد OJ Reeves (@TheColonial) وChristian Mehlmauer (@firefart). العنوان http://3.88.28.22:8000؛ الطريقة GET؛ 10 خيوط تنفيذ؛ قائمة الكلمات /usr/share/wordlists/dirb/common.txt؛ رمز الحالة المستبعد 404؛ وكيل المستخدم gobuster/3.8؛ المهلة 10 ثوانٍ. يبدأ Gobuster في وضع حصر الأدلة. النتائج: /.git/HEAD بالحالة 200 والحجم 23، و/index.html بالحالة 200 والحجم 440. اكتمل 4613/4613 بنسبة 100%. رسالة Wget في 2026-07-02 19:02:32: الوصول إلى http://3.88.28.22:8000/.git/؛ تم الاتصال بالعنوان 3.88.28.22:8000. قوائم الطرفية: الجلسة، الإجراءات، تحرير، عرض، مساعدة.

التوصيات

- إزالة الدليل .git من بيئات الإنتاج.
- ضبط خادم الويب لمنع الوصول إلى الملفات والأدلة المخفية.
- التأكد من أن حزم نشر التطبيقات لا تتضمن مستودعات التحكم في الإصدارات.

F-11 - انكشاف لوحة مراقبة دون مصادقة

الوصف

حُددت أثناء الفحص الكامل للمنافذ باستخدام Nmap خدمة HTTP متاحة على المنفذ 8080. وعند الوصول إليها، اتضح أنها لوحة مراقبة داخلية باسم MegaCorp Monitoring مكشوفة للعامة ومتاحة دون أي آلية مصادقة. كما أشارت الخدمة نفسها إلى تفعيل عرض محتويات الأدلة، مما يزيد انكشاف المعلومات الحساسة.

الأدلة

الأداة المستخدمة:

```
nmap -Pn -p- -sV 3.88.28.22
```

اكتُشفت الخدمة التالية:

```
8080/tcp open http Caddy httpd
```

الترجمة: المنفذ `8080/tcp` مفتوح، والخدمة HTTP، والبرنامج Caddy httpd.

جرى بعد ذلك الوصول إلى الخدمة باستخدام:

```
curl http://3.88.28.22:8080
```

واستُخرجت الاستجابة التالية:

```
MegaCorp Monitoring
Internal monitoring dashboard, exposed on a non-standard port (8080) with no authentication.
FLAG{exposed_monitoring_8080}
Directory listing is enabled - see /status.txt
```

الترجمة:

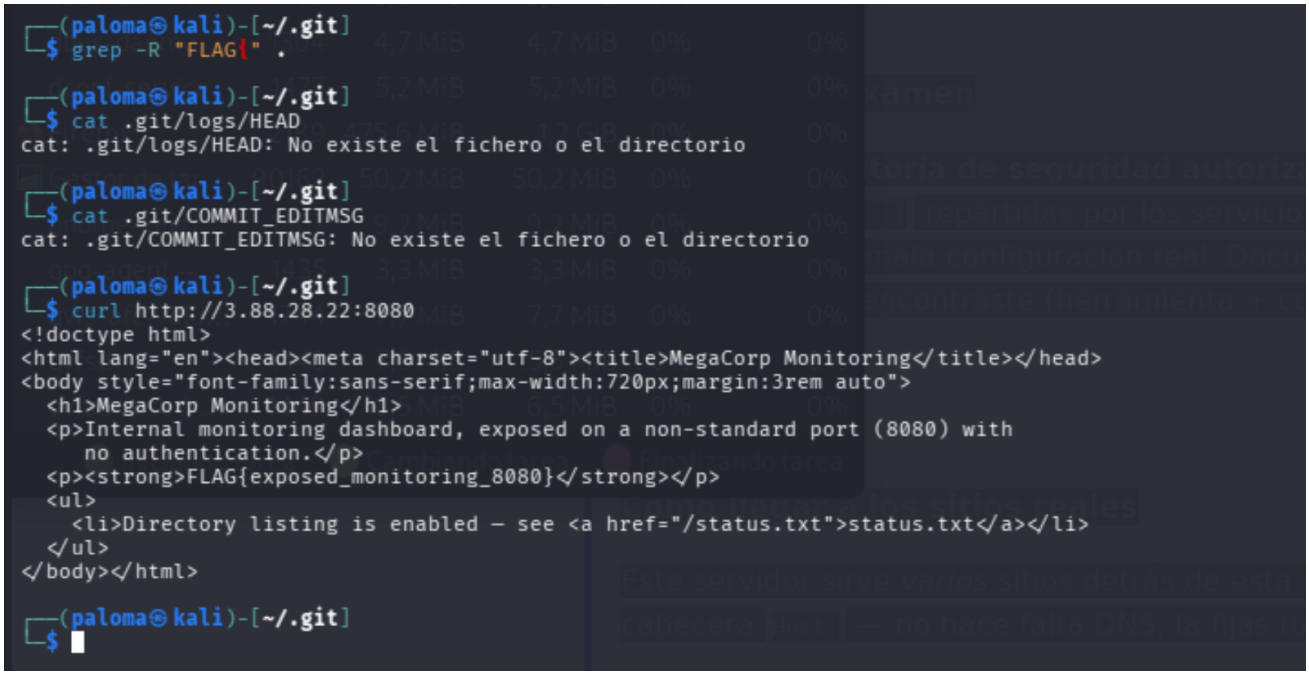
> مراقبة MegaCorp. لوحة مراقبة داخلية مكشوفة على منفذ غير قياسي، هو 8080، دون مصادقة.
> `FLAG{exposed_monitoring_8080}`. عرض محتويات الأدلة مفعّل؛ راجع `/status.txt`.

الأثر

- وصول غير مصرح به إلى لوحة مراقبة داخلية.
- انكشاف معلومات تشغيلية عن البنية التحتية.
- زيادة سطح الهجوم بنشر خدمات إدارية يمكن الوصول إليها من الإنترنت.
- قد يسهّل عرض محتويات الأدلة حصول المهاجم على معلومات إضافية.

درجة الخطورة

مرتفعة.



الشكل 18. اكتشاف لوحة مراقبة مكشوفة على المنفذ 8080.

توضح الصورة الوصول إلى خدمة HTTP المكتشفة أثناء الفحص الكامل للمنافذ بواسطة Nmap. وعند الاتصال بالمنفذ 8080 باستخدام `curl`، اتضح أن الخادم يستضيف لوحة مراقبة داخلية باسم MegaCorp Monitoring متاحة للعامة دون مصادقة. تضمنت الاستجابة `FLAG{exposed_monitoring_8080}`، مما أكد الثغرة، وأشارت أيضًا إلى تفعيل عرض محتويات الأدلة مع إحالة إلى `/status.txt`. يثبت ذلك وجود إعداد غير آمن قد يسهّل إفشاء معلومات حساسة عن البنية التحتية ويزيد سطح هجوم النظام.

ترجمة الرسائل الإضافية: يُبلغ الأمر `cat` عن عدم وجود الملف أو الدليل عند طلب `.git/logs/HEAD`.
و`.git/COMMIT_EDITMSG`.. استجابة لوحة المراقبة مترجمة بالكامل في صفحة الأصل 42. حُفظت الأوامر وترميز HTML في لقطة الأصل؛ والخلفية مترجمة في صفحة الأصل 2.

التوصيات

- تقييد الوصول إلى لوحة المراقبة بمصادقة قوية.
- قصر الوصول إلى الخدمة بواسطة جدار ناري أو VPN أو قوائم ACL.
- تعطيل عرض محتويات الأدلة على خادم الويب.
- تجنب كشف الخدمات الداخلية على منافذ متاحة للعامة، وتنفيذ عمليات تدقيق دورية لاكتشاف هذا النوع من الإعدادات غير الآمنة.

6. سلسلة الهجوم: سرد الأحداث

بدأ التدقيق بمرحلة الاستطلاع، التي حُدد فيها وجود مضيفات افتراضية متعددة واستُخرجت معلومات مهمة من شهادة TLS، ضمن النتائج F-01 وF-02 وF-08. أتاحت المعلومات الواردة في الأسماء البديلة للموضوع SAN اكتشاف نطاقات داخلية جديدة لم تكن ظاهرة في البداية.

بعد ذلك، أتاح تعديل ترويسة `Host` الوصول إلى مضيفات افتراضية داخلية، ضمن F-09، والحصول على معلومات حساسة عن البنية التحتية، واكتشاف تطبيق فوترة قديم ومستودع Git نُشر عرضيًا.

ثم أتاح الفحص الكامل للمنافذ تحديد خدمات إضافية، منها تطبيق Legacy Billing بدليله `git`. المكشوف، ضمن F-10، ولوحة مراقبة داخلية متاحة دون مصادقة على المنفذ 8080، ضمن F-11.

أتاح الجمع بين هذه النتائج توسيع المعرفة بالبنية التحتية تدريجيًا، والعثور على موارد داخلية، وإثبات أن خدمات حرجة متعددة متاحة من الإنترنت بسبب إعدادات غير آمنة وغياب إجراءات التقوية الأمنية المناسبة.

ملخص سلسلة الهجوم:

`F-01 → F-02 → F-08 → F-09 → F-10 → F-11` ثم الحصول على معلومات حساسة والوصول إلى موارد داخلية وتوسيع سطح الهجوم عبر أخطاء إعداد متعددة.

7. الاستنتاجات والتوصيات

الوضع الأمني العام

تتسم البنية التحتية الخاضعة للتدقيق بوضع أمني ضعيف نتيجة تراكم أخطاء الإعداد وانكشاف المعلومات الحساسة. حُددت ثغرات متعددة أتاحت اكتشاف مضيفات افتراضية داخلية، والوصول إلى خدمات مقيدة، وكشف مستودعات Git، والحصول على معلومات عن

البنية التحتية عبر شهادات TLS، والوصول إلى خدمات إدارية دون مصادقة. يسهّل مجموع هذه النتائج أعمال الاستطلاع بدرجة كبيرة ويزيد سطح هجوم النظام.

الأنماط المشتركة للأسباب الجذرية

- كشف معلومات حساسة أثناء الاستطلاع.
- إعداد غير آمن لخوادم الويب.
- انكشاف مستودعات Git والملفات الداخلية.
- غياب التقوية الأمنية عن الخدمات المنشورة.
- انعدام آليات المصادقة في الخدمات الداخلية.
- كشف الأدلة والموارد عبر عرض محتويات الأدلة.
- إفشاء معلومات البنية التحتية عبر شهادات TLS.

خطة المعالجة بحسب الأولوية

الأولوية	الإجراء	النتائج التي يعالجها	الجهد
1	إزالة جميع مستودعات `.git` وأي ملفات حساسة من بيئات الإنتاج.	F-03, F-10	منخفض
2	تقييد الوصول إلى المضيفات الافتراضية والخدمات الداخلية بالمصادقة أو جدار ناري أو VPN.	F-09, F-11	متوسط
3	تعطيل عرض محتويات الأدلة وحماية الموارد المنشورة على خوادم الويب.	F-06, F-10, F-11	منخفض
4	مراجعة إعداد TLS لإزالة الأسماء الداخلية من الشهادات، واستخدام شهادات صادرة عن جهة موثوقة.	F-08	منخفض

الأولوية	الإجراء	النتائج التي يعالجها	الجهد
5	تطبيق التقوية الأمنية على جميع الخدمات المكشوفة، وإزالة التطبيقات المتقادمة وتقليل سطح الهجوم.	F-01, F-02, F-07, F-10, F-11	متوسط
6	وضع إجراء للمراجعة الأمنية قبل النشر، وإجراء تدقيقات دورية للإعدادات وانكشاف الخدمات.	جميع النتائج من F-01 إلى F-11	متوسط

8. الملاحق

استُخدمت أثناء الاستطلاع والحصر أدوات معيارية للتدقيق الأمني، إلى جانب قوائم الكلمات المضمّنة افتراضيًا في Kali Linux.

الأدوات المستخدمة

- Nmap: فحص المنافذ واكتشاف الخدمات.
- cURL: إرسال طلبات HTTP وتعديل ترويسة `Host`.
- OpenSSL: فحص شهادة TLS.
- Gobuster: حصر الأدلة وموارد الويب.
- Git: تحليل المستودع المكشوف.
- Wget: تنزيل الموارد من الخادم.

قوائم الكلمات المستخدمة

- `/usr/share/wordlists/dirb/common.txt`

استُخدمت هذه القائمة مع Gobuster لتحديد الأدلة والموارد المتاحة في خدمات HTTP المكشوفة.

السكربتات الخاصة

استُخدم سكربت Bash صغير لأتمتة حصر المضيفات الافتراضية المستخرجة من شهادة TLS:

```
for h in www.megacorp.lab dev.megacorp.lab admin.megacorp.lab api.megacorp.lab internal.megacorp.lab
staging.megacorp.lab vpn.megacorp.lab; do
    echo "===== $h ====="
    curl -ks -H "Host: $h" https://3.88.28.22 | head -30
    echo
done
```

أتاح هذا السكربت تحديد المضيفات الافتراضية المختلفة المنشورة على الخادم، والعثور على موارد داخلية، واكتشاف عدة رموز إثبات في التمرين.